웹 서비스

1. 계정 관리 ····· 274

2. 서비스 관리 ····· 280

3. 보안 설정 ····· 325

4. 패치 및 로그 관리 ····· 347

01 웹 서비스 취약점 분석 · 평가 항목

1. 계정 관리

점검항목	항목 중요도	항목코드
Default 관리자 계정명 변경	상	WEB-01
취약한 비밀번호 사용 제한	상	WEB-02
비밀번호 파일 권한 관리	상	WEB-03

2. 서비스 관리

점검항목	항목 중요도	항목코드
웹 서비스 디렉터리 리스팅 방지 설정	상	WEB-04
지정하지 않은 CGI/ISAPI 실행 제한	상	WEB-05
웹 서비스 상위 디렉터리 접근 제한 설정	상	WEB-06
웹 서비스 경로 내 불필요한 파일 제거	중	WEB-07
웹 서비스 파일 업로드 및 다운로드 용량 제한	하	WEB-08
웹 서비스 프로세스 권한 제한	상	WEB-09
불필요한 프록시 설정 제한	상	WEB-10
웹 서비스 경로 설정	중	WEB-11
웹 서비스 링크 사용 금지	중	WEB-12
웹 서비스 설정 파일 노출 제한	상	WEB-13
웹 서비스 경로 내 파일의 접근 통제	상	WEB-14
웹 서비스의 불필요한 스크립트 매핑 제거	상	WEB-15
웹 서비스 헤더 정보 노출 제한	중	WEB-16
웹 서비스 가상 디렉토리 삭제	중	WEB-17
웹 서비스 WebDAV 비활성화	상	WEB-18

3. 보안 설정

점검항목	항목 중요도	항목코드
웹 서비스 SSI(Server Side Includes) 사용 제한	중	WEB-19
SSL/TLS 활성화	상	WEB-20
HTTP 리디렉션	중	WEB-21
에러 페이지 관리	하	WEB-22
LDAP 알고리즘 적절하게 구성	중	WEB-23

4. 패치 및 로그 관리

점검항목	항목 중요도	항목코드
별도의 업로드 경로 사용 및 권한 설정	중	WEB-24
주기적 보안 패치 및 벤더 권고사항 적용	상	WEB-25
로그 디렉터리 및 파일 권한 설정	중	WEB-26

WEB-01 (상)	웹 서비스 〉 1. 계정 관리
	Default 관리자 계정명 변경
개요	
점검 내용	웹 서비스 설치 시 기본적으로 설정된 관리자 계정의 변경 후 사용 여부 점검
점검 목적	기본 관리자 계정명과 같은 알려진 계정명을 유추하기 어려운 계정명으로 변경 후 사용하여 공격자에 의한 추측 공격 및 무단 접근 등을 방지하고 보안을 강화하기 위함
보안 위협	기본 관리자 계정명을 변경하지 않고 사용할 경우, 공격자에 의한 계정 및 비밀번호 추측 공격이 가능하고, 이를 통해 불법적인 접근, 데이터 유출, 시스템 장애 등의 보안 사고가 발생할 수 있는 위험이 존재함
참고	※ **기본 계정:** 웹 서비스 설치 시 기본적으로 생성되는 관리자 콘솔 계정 ※ **서비스별 기본 계정:** IIS(Administrator), Tomcat(tomcat, admin), JEUS(administrator)
점검 대상 및 판단 기준	
대상	Tomcat, JEUS
판단 기준	**양호 :** 관리자 페이지를 사용하지 않거나, 계정명이 기본 계정명으로 설정되어 있지 않은 경우
	취약 : 계정명이 기본 계정명으로 설정되어 있거나, 추측하기 쉬운 문자 조합으로 이루어진 계정명을 사용하는 경우
조치 방법	기본 관리자 계정명을 추측하기 어려운 계정명으로 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● Tomcat

Step 1) 기본 계정명 변경 또는 관리자 페이지 비활성화(기본값: 비활성화)

vi <Tomcat 설치 디렉터리>/conf/server.xml

예시) <user username="admin" password="XNDJxndn264!@" roles="manager-gui"/>

Step 2) Tomcat 재구동

systemctl restart tomcat

※ “roles = manager-gui, manager-script, manager-jmx, manager-status” 설정 시 관리자 계정 및 페이지 활성화 상태

JEUS

Step 1) Security > Security Domains 페이지 해당 도메인 > Account & Policies Management > Users > 기본 관리자 계정의 Name 확인

[기본 관리자 계정 확인]

Step 1) Lock & EDIT > Security > Security Domains 페이지 해당 도메인 > Account & Policies Management > Users > ADD > 기본 관리자 계정의 Name을 유추하기 어려운 계정 이름 입력 > Administrators 그룹 체크 후 확인 > Accounts & Policies Management > policies > Role Permissions > AdministratorsRole > “Activate Changes”을 눌러 설정 저장(웹 서비스명과 연관된 단어 “administrator” 계정명 사용금지) > “Activate Changes”을 눌러 설정 저장

Step 2) JEUS 재구동

./stopServer –host [도메인명]:[포트 번호]

./startDomainAdminServer –host [도메인명]:[포트 번호]

※ 기본 계정명 변경이 불가능할 경우 초기 비밀번호 변경으로 보완 필요

WEB-02 (상)	웹 서비스 〉 1. 계정 관리
	취약한 비밀번호 사용 제한
개요	
점검 내용	관리자 계정의 취약한 비밀번호 설정 여부 점검
점검 목적	관리자 계정의 비밀번호가 복잡도 기준에 맞게 적용되어 있는지 점검하여, 비인가자에 의한 비밀번호 유추 공격 및 관리자 권한 탈취 등을 방지하기 위함
보안 위협	관리자 계정의 비밀번호를 취약하게 설정하여 사용하는 경우, 비인가자의 비밀번호 유추 공격으로 관리자 권한 탈취 및 시스템 침입 등의 위험이 존재함
참고	-
점검 대상 및 판단 기준	
대상	Tomcat, IIS, JEUS
판단 기준	**양호 :** 관리자 비밀번호가 암호화되어 있거나, 유추하기 어려운 비밀번호로 설정된 경우
	취약 : 관리자 비밀번호가 암호화되어 있지 않거나, 유추하기 쉬운 비밀번호로 설정된 경우
조치 방법	복잡도 기준에 맞는 추측하기 어려운 비밀번호 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

- **Tomcat**

Step 1) 복잡도를 만족하는 비밀번호 설정

```
# vi <Tomcat 설치 디렉터리>/conf/server.xml
<user username="admin" password="XNDJxndn264!@" roles="manager-gui"/>
```

Step 2) Tomcat 재시작

```
# systemctl restart tomcat
```

- **JEUS**

Step 1) Lock & EDIT > Security > Security Domains 페이지 해당 도메인 > Account & Policies Management > Users > 기본 관리자 계정의 비밀번호 변경 > 확인 > “Activate Changes”을 눌러 설정 저장

[관리자 비밀번호 설정]

※ SHA-256 이상 암호화 방식 비밀번호로 설정

[비밀번호 설정 기준]

1. 영문, 숫자, 특수문자를 조합하여 계정명과 상이한 8자 이상의 비밀번호 설정

※ 다음 각 항목의 문자 종류 중 2종류 이상을 조합하여 최소 10자리 이상 또는 3종류 이상을 조합하여 최소 8자리 이상의 길이로 구성

(1) 영문 대문자(26개)

(2) 영문 소문자(26개)

(3) 숫자(10개)

(4) 특수문자(32개)

2. 비밀번호는 비인가자에 의한 추측이 어렵게 다음의 사항을 반영하여 설계

(1) Null(공백) 비밀번호 사용금지

(2) 문자 또는 숫자만으로 구성 금지

(3) 사용자 ID와 같거나 유사하지 않은 비밀번호 금지

(4) 연속적인 문자나 숫자 사용

예시) 1111, 1234, abcd 사용금지

(5) 주기성 비밀번호 재사용 금지

(6) 전화번호, 생일과 같이 추측하기 쉬운 개인정보를 비밀번호로 사용금지

1. SAM 파일에 암호를 저장하기 위해 사용되는 LANMan 알고리즘은 8자 단위로 글자를 나누어 암호화하기 때문에 8의 배수가 되는 암호 사용 권장 (8자로 이루어진 암호 사용 권장)

3. 아래와 같은 암호 설정 지양

(1) Null, 계정과 같거나 유사한 스트링, 지역명, 부서명, 담당자명, 대표 업무명 “root”, “rootroot”, “root123”, “123root”, “admin”, “admin123”, “123admin”, “osadmin”, “adminos”

WEB-03 (상)	웹 서비스 〉 1. 계정 관리
	비밀번호 파일 권한 관리
개요	
점검 내용	비밀번호 파일에 대해 적절한 접근 권한 설정 여부 점검
점검 목적	비밀번호 파일의 접근 권한을 적절하게 설정하여 비인가자가 비밀번호 파일에 무단 접근 및 유출 등을 방지하기 위함
보안 위협	비밀번호 파일의 권한을 적절하게 설정하지 않은 경우, 비인가자에게 비밀번호 정보가 노출될 수 있고 웹 서버에 접속하는 등의 침해사고가 발생할 위험이 존재함
참고	-
점검 대상 및 판단 기준	
대상	Tomcat, IIS, JEUS
판단 기준	**양호 :** 비밀번호 파일에 권한이 600 이하로 설정된 경우
	취약 : 비밀번호 파일에 권한이 600 초과로 설정된 경우
조치 방법	비밀번호 파일 권한 600 이하로 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

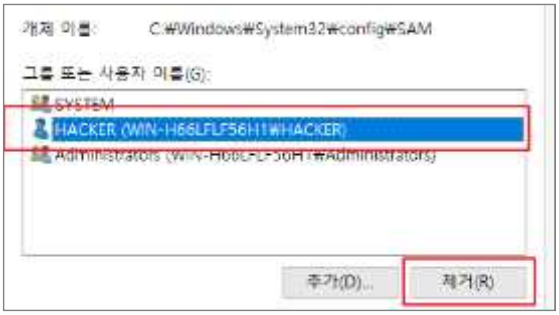
- Tomcat

Step 1) tomcat-users.xml 파일 권한 변경

```
# chmod 600 /<Tomcat 설치 디렉터리>/tomcat-users.xml
```

- IIS

Step 1) “%systemroot%\system32\config\SAM” 파일 속성 > 보안 > 편집 > Administrators, SYSTEM을 제외한 계정 및 그룹 권한 제거



[SAM 파일 권한 설정]

JEUS

Step 1) [비밀번호 파일] 또는 [Role 파일] 권한 설정

```
# chmod 600 /<JEUS 설치 디렉터리>/jeus_domain/config/security/SYSTEM_DOMAIN/accounts.xml
# chmod 600 /<JEUS 설치 디렉터리>/jeus_domain/config/security/SYSTEM_DOMAIN/policies.xml
```

Step 2) JEUS 재시작

```
# ./stopServer –host <도메인명>:<포트 번호>
# ./startDomainAdminServer –host <도메인명>:<포트 번호>
```

WEB-04 (상)	웹 서비스 〉 2. 서비스 관리
	웹 서비스 디렉터리 리스팅 방지 설정
개요	
점검 내용	디렉터리 리스팅 기능 차단 여부 점검
점검 목적	웹 서버에 대한 디렉터리 리스팅 기능을 차단하여 디렉터리 내의 모든 파일에 대한 접근 및 정보 노출을 차단하기 위함
보안 위협	디렉터리 리스팅 기능이 차단되지 않은 경우, 비인가자가 해당 디렉터리 내의 모든 파일의 리스트 확인 및 접근이 가능하고, 웹 서버의 구조 및 백업 파일이나 소스 파일 등 공개되면 안 되는 중요 파일들이 노출될 위험이 존재함
참고	※ **디렉터리 리스팅(Directory Listing):** 웹 서버의 취약한 설정으로 인해 웹 서버의 파일 시스템 목록을 보여주는 것
점검 대상 및 판단 기준	
대상	Apache, Tomcat, Nginx, IIS, JEUS, WebtoB
판단 기준	**양호 :** 디렉터리 리스팅이 설정되지 않은 경우
	취약 : 디렉터리 리스팅이 설정된 경우
조치 방법	디렉터리 리스팅 기능 차단 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

- **Apache**

Step 1) httpd.conf 파일 내 모든 디렉터리의 Options 지시자에서 Indexes 옵션 제거

```
# vi /<Apache 설치 디렉터리>/httpd.conf(또는 apache.conf)
<Directory />
  Options Indexes  삭제 (또는 –Indexes 설정)
</Directory>
```

Step 2) Apache 재시작

```
# systemctl restart apache2
```

※ httpd.conf 뿐 아니라 sites-available 디렉터리 내 모든 사이트에 적용

※ 파일 위치 및 서비스명은 사용하는 운영체제에 따라 달라질 수 있음

Tomcat

Step 1) web.xml 파일 내 listings 옵션 비활성화

```
# vi /<Tomcat 설치 디렉터리>/web.xml
  <init-param>
    <param-name>listings</param-name>
    <param-value>false</param-value>
  </init-param>
```

Nginx

Step 1) nginx.conf 파일 내 autoindex 지시자 off 설정

```
# vi /<Nginx 설치 디렉터리>/conf/nginx.conf
server {
        autoindex off;
}
```

Step 2) Nginx 재시작

```
# systemctl restart nginx
```

IIS

Step 1) 시작 > Windows 관리 도구 > 인터넷 정보 서비스(IIS) 관리자 > 해당 웹 사이트 > IIS > 디렉터리 검색 선택, 사용"을 "사용 안 함"으로 설정

[디렉터리 검색 기능 비활성화]

JEUS

Step 1) jeus-web-dd.xml 파일 내 디렉터리 리스팅 설정 변경

```
# vi /<JEUS 설치 디렉터리>/WEB-INF/jeus-web-dd.xml
    <allow-indexing>false</allow-indexing>
```

WebtoB

Step 1) *Node, *URL 절에 Options 지시자 설정 삭제 또는 “-Indexes”로 설정

```
# nano /<WebtoB 설치 디렉터리>/config/http.m
*NODE
imuser   WEBTOBDIR="/root/webtob",
         Options = "-Indexes",
```

Step 2) 설정 파일 컴파일 및 재시작

```
# wscfl -I http.m
# wsdown
# wsboot
```

WEB-05 (상)	웹 서비스 〉 2. 서비스 관리
	지정하지 않은 CGI/ISAPI 실행 제한
개요	
점검 내용	웹 서비스 CGI 실행 제한 설정 여부 점검
점검 목적	CGI 스크립트를 정해진 디렉터리에서만 실행되도록 하여 악의적인 파일의 업로드 및 실행을 방지하기 위함
보안 위협	게시판이나 자료실과 같이 업로드되는 파일이 저장되는 디렉터리에 CGI 스크립트가 실행 가능한 경우 악의적인 파일을 업로드하고 이를 실행하여 시스템의 중요 정보가 노출될 수 있으며 침해사고의 경로로 이용될 위험이 존재함
참고	※ CGI(Common Gateway Interface): 사용자가 서버로 보낸 데이터를 서버에서 작동 중인 데이터 처리프로그램에 전달하고, 여기에서 처리된 데이터를 다시 서버로 되돌려 보내는 등의 일을 하는 표준 인터페이스 규격
점검 대상 및 판단 기준	
대상	Apache, Tomcat, Nginx, IIS, WebtoB
판단 기준	**양호 :** CGI 스크립트를 사용하지 않거나 CGI 스크립트가 실행 가능한 디렉터리를 제한한 경우
	취약 : CGI 스크립트를 사용하고 CGI 스크립트가 실행 가능한 디렉터리를 제한하지 않은 경우
조치 방법	CGI 스크립트를 정해진 디렉터리 내에서만 실행할 수 있도록 설정
조치 시 영향	해당 디렉터리 확인 후 추가적인 파일이 없다면 영향 없음

점검 및 조치 사례

● Apache

Step 1) apache 설정 파일 내 CGI 모듈 비활성화 또는 주석 처리

```
#  vi /<Apache 설치 디렉터리>/httpd.conf(또는 apache.conf)
#LoadModule cgi_module modules/mod_cgi.so
#LoadModule cgid_module modules/mod_cgid.so
```

Step 2) apache 설정 파일 내 설정된 모든 디렉터리의 Options 지시자에서 ExecCGI 옵션 제거

```
# vi /<Apache 설치 디렉터리>/apache.conf(또는 httpd.conf)
<Directory "/var/www/cgi-bin">
   Options -ExecCGI
</Directory>
```

Step 3) Apache 재시작

Tomcat

Step 1) web.xml 파일 내 CGI 매핑 비활성화

```
<!-- <servlet-mapping>
  <servlet-name>cgi</servlet-name>
  <url-pattern>/cgi-bin/*</url-pattern>
 </servlet-mapping> -->
```

Step 2) Tomcat 재시작

Nginx

Step 1) nginx.conf 파일 내 Fastcgi 사용 여부 확인

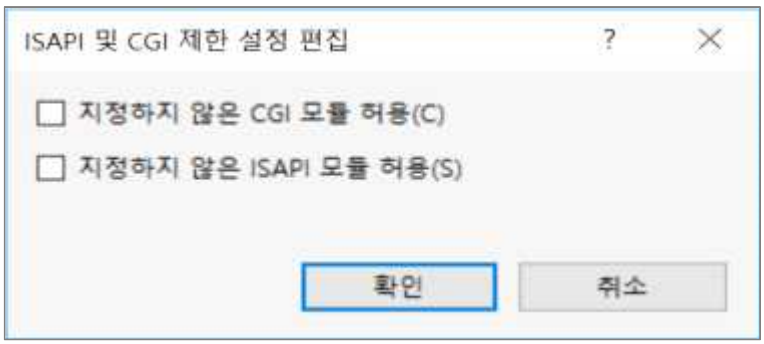
```
# cat /<Nginx 설치 디렉터리>/conf/nginx.conf
location ~ \.cgi$ {
        #fastcgi_pass <FastCGI 서버 주소>:<FastCGI 서버 통신 포트>;
        #include fastcgi_params;
}
```

Step 2) Nginx 재시작

IIS

Step 1) CGI 디렉터리 설정 해제

IIS 관리자 > 서버 선택 > ISAPI 및 CGI 제한 > 기능 열기 > 작업 > 기능 설정 편집 > 사용하지 않는 CGI/ISAPI 모듈 설정 해제



[CGI/ISAPI 모듈 설정 확인]

WebtoB

Step 1) http.m 파일 내 활성화되어 있는 *SVRGROUP, *SERVER, *URI 절에서 CGI 옵션 제거 또는 비활성화

```
# vi /<WebtoB 설치 디렉터리>/config/http.m“
*SVRGROUP
htmlg           SVRTYPE = HTML
#cgig           SVRTYPE = CGI
ssig            SVRTYPE = SSI
jsvg            SVRTYPE = JSV

*SERVER
#cgi            SVGNAME = cgig, MinProc = 2, MaxProc = 10, ASQCount = 1
ssi             SVGNAME = ssig, MinProc = 2, MaxProc = 10, ASQCount = 1
MyGroup                 SVGNAME = jsvg, MinProc = 20, MaxProc = 20
*URI
#uri1           Uri = "/cgi-bin/",   Svrtype = CGI
```

Step 2) 설정 파일 컴파일 및 재구동

```
# wscfl -I http.m
# wsdown
# wsboot
```

※ 필요한 경우 해당 디렉터리만 제한적으로 CGI 스크립트 실행 설정

WEB-06 (상)	웹 서비스 〉 2. 서비스 관리
	웹 서비스 상위 디렉터리 접근 제한 설정
개요	
점검 내용	“..” 와 같은 문자사용 등을 통한 상위 디렉터리 접근 제한 여부 점검
점검 목적	상위 디렉터리 접근 제한 설정을 통해 비인가자의 특정 디렉터리에 대한 접근 및 열람을 제한하여 중요 파일 및 데이터를 보호하고, Unicode 버그 및 서비스 거부 공격 등을 방지하기 위함
보안 위협	• 상위 디렉터리로 이동하는 것이 가능할 경우 접근하고자 하는 디렉터리의 하위 경로에서 상위로 이동하며 정보 탐색이 가능하여 중요 정보가 노출될 위험이 존재함 • 악의적인 목적을 가진 사용자가 중요 파일 및 디렉터리의 접근이 가능하여 데이터가 유출될 위험이 존재함
참고	※ “..” 는 Unicode 버그, 서비스 거부와 같은 공격에 쉽게 이용되므로 허용하지 않는 것을 권장함
점검 대상 및 판단 기준	
대상	Apache, Tomcat, Nginx, IIS, WebtoB
판단 기준	**양호 :** 상위 디렉터리 접근 기능을 제거한 경우
	취약 : 상위 디렉터리 접근 기능을 제거하지 않은 경우
조치 방법	상위 디렉터리 접근 기능 제거 설정
조치 시 영향	웹 서버 및 웹 서비스의 특성에 따라 영향을 줄 수 있음

점검 및 조치 사례

● Apache

Step 1) AllowOverride 지시자 Authconfig 옵션 설정 확인

```
# vi /<Apache 설치 디렉터리>/httpd.conf(또는 apache.conf)
<Directory “/usr/local/apache2/htdocs”>
  AllowOverride None
</Directory>
```

Step 2) AllowOverride 지시자 AuthConfig 옵션 설정

```
#  vi /<Apache 설치 디렉터리>/httpd.conf(또는 apache.conf)
<Directory “/usr/local/apache2/htdocs”>
  AllowOverride AuthConfig
</Directory>
```

Step 3) 사용자 인증을 설정할 디렉터리에 .htaccess 파일 생성

AuthName “디렉터리 사용자 인증”

AuthType Basic

AuthUserFile /usr/local/apache/test/.auth

Require valid-user

지시자	설명
AuthName	인증 영역(웹 브라우저의 인증 창에 표시되는 문구)
AuthType	인증 형태(Basic 또는, Digest)
AuthUserFile	사용자 정보(아이디 및 비밀번호) 저장 파일 위치
AuthGroupFile	그룹 파일의 위치(옵션)
Require	접근을 허용할 사용자 또는, 그룹 정의

Step 4) 사용자 인증에 사용할 아이디 및 비밀번호 생성

htpasswd /<Apache 설치 디렉터리>/.htpasswd [사용자명]

New password: <비밀번호 입력>

Re-type new password: <비밀번호 재입력>

Adding password for user <사용자명>

Step 5) Apache 재구동

systemctl restart apache2

Tomcat

Step 1) server.xml 파일 내 Context 요소에서 allowLinking 옵션 확인

vi /<Tomcat 설치 디렉터리>/conf/server.xml

<Context allowLinking=“true”>

<WatchedResource>WEB-INF/web.xml</WatchedResource>

<WatchedResource>WEB-INF/tomcat-web.xml</WatchedResource>

<WatchedResource>${catalina.base}/conf/web.xml</WatchedResource>

</Context>

Step 2) server.xml 파일 내 Context 요소에서 allowLinking 옵션 제거

#vi /<Tomcat 설치 디렉터리>/conf/server.xml

<Context>

```
  <WatchedResource>WEB-INF/web.xml</WatchedResource>
  <WatchedResource>WEB-INF/tomcat-web.xml</WatchedResource>
  <WatchedResource>${catalina.base}/conf/web.xml</WatchedResource>
</Context>
```

- **Nginx**

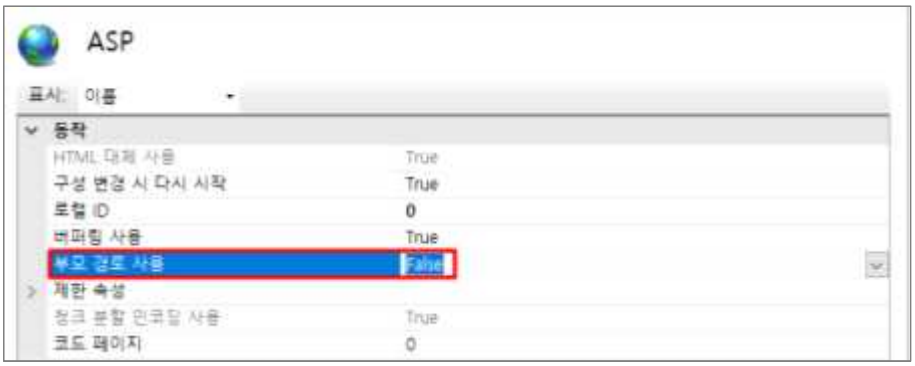
Step 1) nginx.conf 파일 내 디렉터리 접근을 기본 인증으로 제한 설정

```
# cat /<Nginx 설치 디렉터리>/conf/nginx.conf
location /<접근제한 디렉터리>/ {
        auth_basic "Restricted Content";
        auth_basic_user_file /etc/nginx/.htpasswd;
}
```

- **IIS 6.0 이하**

Step 1) 부모 경로 사용 설정

시작 > Windows 관리 도구 > 인터넷 정보 서비스(IIS) 관리자 > 웹 사이트 > IIS > ASP > “부모 경로 사용” 항목 “False” 설정



[부모 경로 설정 확인]

- **IIS 7.0 이상**

Step 1) 제어판 > 관리 도구 > 인터넷 정보 서비스(IIS) 관리자 > 해당 웹사이트 > 사이트 편집에서 루트 디렉터리 > 루트 디렉터리의 web.config 파일에서 “enableParentPaths” 요소를 “False”로 설정

```
<configuration>
  <system.web>
```

```
    <httpRuntime enableParentPaths="false" />
  </system.web>
</configuration>
```

※ web.config 파일이 없으면 사이트 홈 디렉터리에 새로 생성

- **WebtoB**

Step 1) http.m 파일 내 활성화되어 있는 UpperDirRestrict 옵션 제거 또는 비활성화

```
# vi /<WebtoB 설치 디렉터리>/config/http.m
UpperDirRestrict = N
```

Step 2) 확인 후 설정 파일 컴파일 및 재구동

```
# wscfl -I http.m
# wsdown
# wsboot
```

WEB-07 (중)	웹 서비스 〉 2. 서비스 관리
	웹 서비스 경로 내 불필요한 파일 제거
개요	
점검 내용	웹 서비스 설치 시 기본으로 생성되는 불필요한 파일 및 디렉터리 제거 여부 점검
점검 목적	웹 서비스 설치 시 기본으로 생성되는 샘플, 매뉴얼 파일 등 서비스에 불필요한 파일을 제거하여 불필요한 공격 대상으로 이용되는 것을 방지하기 위함
보안 위협	웹 서비스 설치 시 기본으로 생성되는 파일 및 디렉터리나 백업, 테스트 파일 등을 제거하지 않은 경우, 비인가자에게 시스템 관련 정보 및 웹 서버 정보가 노출되거나 해킹에 악용될 수 있음
참고	※ **불필요한 파일:** 샘플 파일, 매뉴얼 파일, 임시 파일, 테스트 파일, 백업 파일 등
점검 대상 및 판단 기준	
대상	Apache, Tomcat, Nginx, IIS, JEUS, WebtoB
판단 기준	**양호 :** 기본으로 생성되는 불필요한 파일 및 디렉터리가 존재하지 않을 경우
	취약 : 기본으로 생성되는 불필요한 파일 및 디렉터리가 존재하는 경우
조치 방법	불필요한 파일 및 디렉터리를 제거하도록 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

- **Apache**

Step 1) rm 명령어로 확인된 불필요한 매뉴얼 디렉터리 및 파일 제거

```
# rm –rf /<Apache 설치 디렉터리>/htdocs/manual
# rm –rf /<Apache 설치 디렉터리>/manual
```

※ 2.4 버전 이상은 htdocs 디렉터리가 기본 제공되지 않으므로 /var/www/html 사용

- **Tomcat**

Step 1) rm 명령어로 확인된 불필요한 매뉴얼 디렉터리 및 파일 제거

```
# rm –rf /<Tomcat 설치 디렉터리>/webapps/docs/<불필요 파일>
```

※ BUILDING.txt, RELEASE-NOTES.txt, jndi-resources-howto.html 등 매뉴얼 파일 포함

- Nginx

Step 1) rm 명령어로 확인된 불필요한 매뉴얼 디렉터리 및 파일 제거

rm –rf /<Nginx 설치 디렉터리>/html/index.html

- IIS

Step 1) 샘플 디렉터리 존재여부 확인 및 제거

샘플 디렉터리 경로 예시
c:\inetpub\iissamples
c:\winnt\help\iishelp
c:\program files\common files\system\msadc\sample
%SystemRoot%\System32\Inetsrv\IISADMPWD

- JEUS

Step 1) rm 명령어로 확인된 불필요한 매뉴얼 디렉터리 및 파일 제거

rm –rf /<JEUS 설치 디렉터리>/docs/manuals/default/web-manager/<불필요 파일>

rm –rf /<JEUS 홈 디렉터리>/samples/ <불필요 파일>

- WebtoB

Step 1) rm 명령어로 확인된 불필요한 매뉴얼 디렉터리 및 파일 제거

rm –rf /<WebtoB 설치 디렉터리>/docs/manuals/<불필요 파일>

rm –rf /<WebtoB 홈 디렉터리>/samples/ <불필요 파일>

WEB-08 (하)	웹 서비스 〉 2. 서비스 관리
	웹 서비스 파일 업로드 및 다운로드 용량 제한
개요	
점검 내용	파일 업로드 및 다운로드의 용량 제한 설정 여부 점검
점검 목적	기반시설 시스템은 원칙적으로 파일 업로드 및 다운로드를 금지하지만 불가피하게 파일의 업로드 및 다운로드 기능이 필요한 경우, 파일의 용량 제한을 설정하여 불필요한 업로드 및 다운로드를 방지해 서버의 과부하를 예방하고, 웹 서버 자원을 효율적으로 관리하기 위함
보안 위협	웹 서비스의 파일 업로드 및 다운로드의 용량을 제한하지 않은 경우, 악의적인 목적을 가진 사용자가 반복 업로드 및 웹 쉘 공격 등으로 시스템 권한을 탈취하거나 대용량 파일의 업로드 및 다운로드로 서버 자원을 고갈시켜 서비스 장애를 발생시킬 위험이 존재함
참고	※ **불필요한 업로드 및 다운로드:** 내부 정책에 맞지 않는 업로드와 다운로드
점검 대상 및 판단 기준	
대상	Apache, Tomcat, Nginx, IIS, JEUS, WebtoB
판단 기준	**양호 :** 파일 업로드 및 다운로드 용량을 제한한 경우
	취약 : 파일 업로드 및 다운로드 용량을 제한하지 않은 경우
조치 방법	파일 업로드 및 다운로드 용량을 허용 가능한 최소 범위로 제한하여 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● Apache

Step 1) 설정 파일 내 LimitRequestBody 지시자에서 파일 용량 제한 설정

```
<Directory />
    LimitRequestBody 5000000
</Directory>
```

● Tomcat

Step 1) server.xml 파일 내 maxPostSize 요소 설정

```
#vi /<Tomcat 설치 디렉터리>/conf/server.xml
<Connector port="<사용 포트>" protocol="HTTP/1.1"
connectionTimeout="20000"
redirectPort="<사용 포트>"
```

maxParameterCount="1000"

maxPostSize="5242880" // maxPostSize=5242880=5MB

/>

Step 2) web.xml 파일 내 multipart-config 요소 설정

vi /<Tomcat 설치 디렉터리>/conf/web.lxml

<multipart-config>

<max-file-size>2097152</max-file-size>

<max-request-size>4194304</max-request-size>

<file-size-threshold>0</file-size-threshold>

</multipart-config>

Nginx

Step 1) nginx.conf 파일 내 client_max_body_size 요소 파일 용량 제한 설정

vi /<Nginx 설치 디렉터리>/nginx.conf

<Directory/>

client_max_body_size 5M; (설정 단위: byte)

</Directory>

Step 2) Nginx 데몬 재구동

systemctl restart nginx

IIS

Step 1) 루트 디렉터리 web.config 파일 설정 파일 내 "maxAllowedContentLength" 설정 확인

```
<configuration>
  <system.webServer>
    <security>
      <requestFiltering>
          <requestLimits maxAllowedContentLength="30000000" />
      </requestFiltering>
    </security>
  </system.webServer>
</configuration>
```

[최대 컨텐츠 파일 용량 제한 설정 확인]

Step 2) 루트 디렉터리 web.config 파일 설정 파일 내 "maxAllowedContentLength" 제한 설정 (기본값: 30MB)

Step 3) applicationHost.config 파일 내 “bufferingLimit” 및 “maxRequestEntity Allowed” 설정

(기본값: bufferingLimit - 4MB, maxRequestEntityAllowed – 0.2MB)

```
<system.webServer>

    <asp>
        <cache diskTemplateCacheDirectory="%SystemDrive%\inetpub\temp\ASP Compiled Templates" />
        <limits bufferingLimit="파일다운로드용량" maxRequestEntityAllowed="파일업로드용량"/>
    </asp>
```

[파일 다운로드 및 파일 업로드 용량 설정]

※ web.config 파일이 없으면 사이트 홈 디렉터리에 새로 생성

● JEUS

Step 1) web.xml 파일 내 max-file-size 지시자에서 파일 용량 제한 설정

#vi /[JEUS 설치 디렉터리]/WEB-INF/web.xml

<multipart-config>

<max-file-size>5242880</max-file-size>

</multipart-config>

※ 출력값이 존재하지 않는 경우 용량을 제한하고 있지 않은 상태로 취약

● WebtoB

Step 1) LimitRequestBody 지시자를 사용하여 파일 업로드 및 다운로드 용량 제한 설정

vi /[WebtoB 설치 디렉터리]/conf/http.m

*NODE

imuser WEBTOBDIR="/home/tmax/webtob/",

SHMKEY = 54000,

DOCROOT="/home/tmax/webtob/docs",

*ALIAS

alias1 URI = "/cgi-bin/", RealPath = "/home/webtob/webtob/cgi-bin/"

LimitRequestBody = 2048000

※ 업로드 및 다운로드 파일이 5MB를 넘지 않도록 설정 권고

WEB-09 (상)	웹 서비스 〉 2. 서비스 관리
	웹 서비스 프로세스 권한 제한
개요	
점검 내용	웹 서비스 프로세스의 관리자 권한 구동 여부 점검
점검 목적	웹 프로세스가 웹 서비스 운영에 필요한 최소한의 권한만을 갖도록 제한함으로써 웹 사이트 방문자가 웹 서비스의 취약점을 이용해 시스템에 대한 어떤 권한도 획득할 수 없도록 하여 침해사고 발생 시 피해 범위 확산을 방지하기 위함
보안 위협	웹 프로세스 권한을 제한하지 않은 경우, 웹 사이트 방문자가 웹 서비스의 취약점을 이용하여 시스템 권한을 획득할 수 있으며, 웹 취약점을 통해 접속 권한을 획득한 경우에는 관리자 권한을 획득하여 서버에 접속 후 정보의 변경, 훼손 및 유출될 위험이 존재함
참고	-
점검 대상 및 판단 기준	
대상	Apache, Tomcat, Nginx, IIS, JEUS, WebtoB
판단 기준	**양호 :** 웹 프로세스(웹 서비스)가 관리자 권한이 부여된 계정이 아닌 운영에 필요한 최소한의 권한을 가진 별도의 계정으로 구동되고 있는 경우
	취약 : 웹 프로세스(웹 서비스)가 관리자 권한이 부여된 계정으로 구동되고 있는 경우
조치 방법	웹 서비스 프로세스 구동 시 관리자 권한이 아닌 운영에 필요한 최소한의 권한을 가진 계정으로 구동 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● Apache

Step 1) envvars 파일 내 실행 계정을 관리자 계정이 아닌 별도의 계정으로 변경

```
# vi /[Apache 설치 디렉터리]/envvars
export APACHE_RUN_USER=www-data
export APACHE_RUN_GROUP=www-data
```

Step 2) Apache 서비스 파일 소유권 변경

```
# chown -R www-data:www-data /etc/apache2/
# chown -R www-data:www-data /var/www/
# chown -R www-data:www-data /var/log/apache2/
```

Step 3) 웹 서비스 실행 계정 로그인 제한 설정

```
# usermod -s /sbin/nologin [사용자명]
```

Step 4) Apache 재구동

systemctl restart apache2 또는 httpd

Tomcat

Step 1) tomcat.service 파일 내 Tomcat 데몬 구동 권한을 관리자 계정이 아닌 별도 계정으로 변경

vi /etc/systemd/system/tomcat.service

[Service]

User=tomcat

Group=tomcat

Step 2) Tomcat 서비스 파일 소유권 변경

chown -R tomcat:tomcat /[Tomcat 설치 디렉터리]/usr/share/tomcat9/

chown -R tomcat:tomcat /[Tomcat 설치 디렉터리]/tomcat9/temp

chown -R tomcat:tomcat / [Tomcat 설치 디렉터리]/logs

chown -R tomcat:tomcat /usr/share/tomcat9/webapps

chown -R tomcat:tomcat /usr/share/tomcat9/work

Step 3) 웹서비스 실행 계정 로그인 제한 설정

usermod -s /sbin/nologin [사용자명]

Step 4) Tomcat 서비스 재구동

systemctl restart tomcat

Nginx

Step 1) nginx.conf 파일 내 Nginx 데몬 구동 권한을 관리자 계정이 아닌 별도 계정으로 변경

vi /[Nginx 설치 디렉터리]/conf/nginx.conf

User nginx nginx;

Step 2) Nginx 전용 계정 생성 및 Nginx 전용 그룹 추가

adduser --system --no-create-home --shell /bin/false nginx

groupadd nginx && sudo usermod -aG nginx nginx

Step 3) 웹서비스 실행 계정 로그인 제한 설정

usermod –s /sbin/nologin [사용자명]

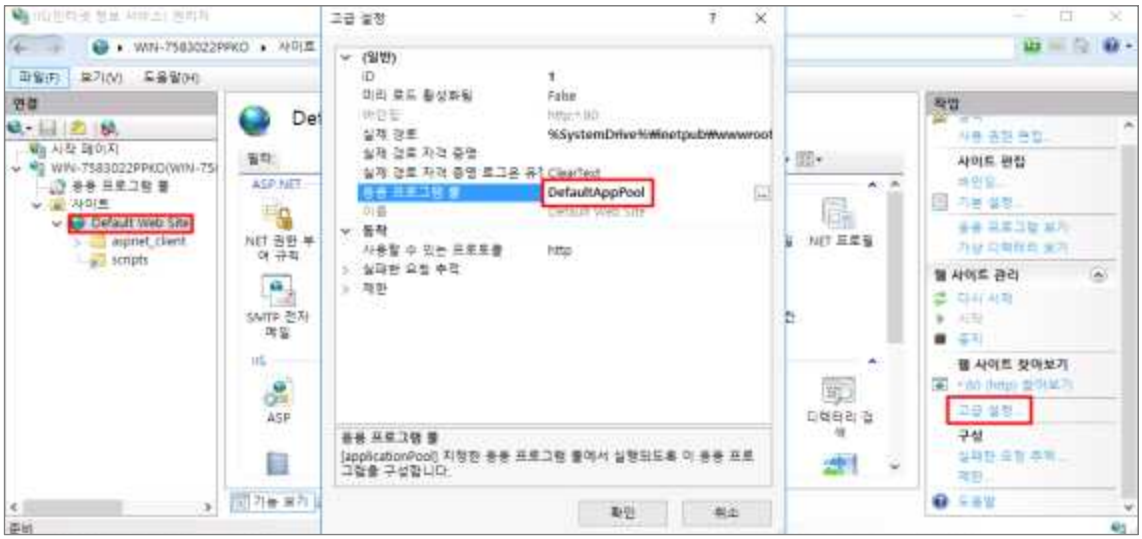
Step 4) Nginx 서비스 재구동

systemctl restart nginx

IIS

Step 1) 웹 사이트 응용프로그램 풀 이름 확인

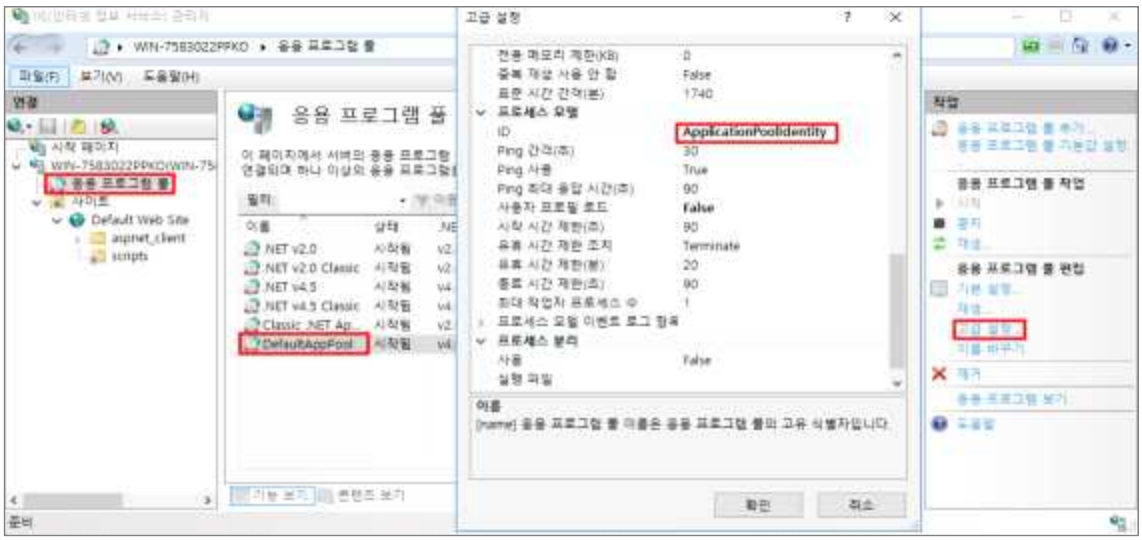
제어판 > 관리 도구 > 인터넷 정보 서비스(IIS) 관리자 > 해당 웹 사이트 > 고급 설정 > '응용프로그램 풀 이름(DefaultAppPool)' 확인



[응용프로그램 풀 이름 확인]

Step 2) 웹 사이트 응용프로그램 풀 ID 확인

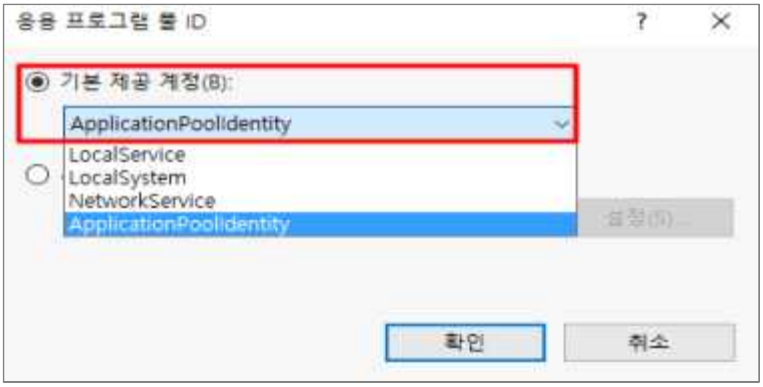
제어판 > 관리 도구 > 인터넷 정보 서비스(IIS) 관리자 > 응용프로그램 풀 > '응용프로그램 풀 이름(DefaultAppPool)' 선택 > 고급 설정 > ID > 확인



[응용프로그램 풀 ID 확인]

Step 3) 웹사이트 응용프로그램 풀 ID 설정

제어판 > 관리 도구 > 인터넷 정보 서비스(IIS) 관리자 > 응용프로그램 풀 > '용용 프로그램 풀 이름(DefaultAppPool)' 선택 > 고급 설정 > ID > ApplicationPoolIdentity 선택



[응용프로그램 풀 ID 설정]

JEUS

Step 1) JEUS 데몬 구동 권한 확인

ps--ef |grep jeus

jeus 25305 4223 99 09:54 pts/5 00:03:31 /usr/lib/jvm/java-11-openjdk-amd64/bin/java-DadminServer...

Step 2) JEUS 데몬 구동 권한을 관리자 계정이 아닌 별도 계정으로 변경

useradd –m jeus

mv /[JEUS 설치 디렉터리]/home/jeus

Step 3) [JEUS 설치 디렉터리] 소유자 및 그룹 소유자를 JEUS 계정으로 변경

chown –R jeus:jeus /home/jeus/

WebtoB

Step 1) 소유자 및 그룹 소유자 변경

chown –R [WebtoB 전용 계정]:[WebtoB 전용 계정] /[WebtoB 디렉터리]

Step 2) http.m 파일 내 기존 경로 변경

*NODE절의 WEBTOBDIR, DOCROOT을 변경한 디렉터리로 설정

예시) *NODE

imuser WEBTOBDIR="/home/tmax/webtob/",

SHMKEY = 54000,

DOCROOT="/home/tmax/webtob/docs",

*ALIAS절의 alias1을 변경한 디렉터리로 설정

예시) *ALIAS

alias1 URI = "/cgi-bin/", RealPath = "/home/webtob/webtob/cgi-bin/"

*LOGGING절의 syslog, log1, log2을 변경한 디렉터리로 설정

예시) *LOGGING

syslog Format = "SYSLOG", FileName = "/home/tmax/webtob/log/system.log>

Option = "sync"

log1 Format = "DEFAULT", FileName = "/home/tmax/webtob/log/access.lo>

Option = "sync"

log2 Format = "ERROR", FileName = "/home/tmax/webtob/log/error.log_%>

Option = "sync"

Step 3) 변경한 디렉터리명 환경변수에 추가

export WEBTOB=/[WebtoB 디렉터리]

source ~/.bashrc

Step 4) libwbiconv.so 파일을 직접 /usr/lib로 복사

cp /webtob/lib/libwbiconv.so /usr/lib/

Step 5) 라이브러리 캐시 업데이트

ldconfig

Step 6) 설정 파일 컴파일

wscfl –i http.m

WEB-10 (상)	웹 서비스 〉 2. 서비스 관리
	불필요한 프록시 설정 제한
개요	
점검 내용	웹 서비스 불필요한 Proxy 설정제한 여부 점검
점검 목적	불필요한 Proxy 설정을 제한하여 자원 낭비 예방 및 관리의 복잡성을 감소시키며, 중간자 공격 등의 해킹 공격으로부터 시스템 관련 정보가 노출되거나 악용되는 것을 방지하기 위함
보안 위협	불필요한 Proxy 설정을 제한하지 않는 경우 공격자가 Proxy 서버를 이용하여 원래 의도되지 않은 방식으로 시스템에 접근하거나 시스템 관련 정보가 유출될 위험이 존재함
참고	-
점검 대상 및 판단 기준	
대상	Apache, Tomcat, Nginx, IIS, JEUS, WebtoB
판단 기준	**양호 :** 불필요한 Proxy 설정을 제한한 경우
	취약 : 불필요한 Proxy 설정을 제한하지 않은 경우
조치 방법	불필요한 Proxy 설정 존재 여부 점검 및 제한 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

- **Apache**

Step 1) apache2.conf (또는 /conf/httpd.conf) 파일 내 불필요한 Proxy 제거

```
<VirtualHost *:80>
  ServerName www.example.com
  ProxyPreserveHost On
  ProxyRequests Off
  ProxyPass / http://backend-server.example.com/
  ProxyPassReverse / http://backend-server.example.com/
</VirtualHost>
```

- **Tomcat**

Step 1) server.xml 파일 내 Connector 요소에서 불필요한 Proxy 설정 제거

```
<Connector port="8080" protocol="HTTP/1.1"
```

```
redirectPort="8443"
proxyName="proxy.example.com"
proxyPort="80" />
```

Nginx

Step 1) nginx.conf 파일 내 웹 사이트에서 불필요한 Proxy 설정 제거

```
# cat /[Nginx 설치 디렉터리/nginx.conf
  location / {
    proxy_pass http://backendserver:8080;
    proxy_set_header Host $host;
    proxy_set_header X-Real-IP $remote_addr;
    proxy_set_header X-Forwarded-For $proxy_add_x_forwarded_for;
  }
```

IIS

Step 1) 제어판 > 관리 도구 > 인터넷 정보 서비스(IIS) 관리자 > 해당 웹 사이트 > 루트 디렉터리에서 불필요한 Proxy 설정 제거

[Proxy 설정 확인 및 제거]

JEUS

Step 1) web.xml 파일 내 불필요한 Proxy 제거

```
# vi /[WebtoB 설치 디렉터리]/ReverseProxy/WEB-INF/web.xml
```

WebtoB

Step 1) http.m 파일 내 불필요 Proxy 설정 제거

```
# vi /[WebtoB 디렉터리]/conf/http.m
REVERSE_PROXY(0): Name = rproxy1,
  PathPrefix = "/proxypath/",
  ServerAddress = "127.0.0.1:8088",
```

WEB-11 (중)	웹 서비스 〉 2. 서비스 관리
	웹 서비스 경로 설정
개요	
점검 내용	웹 서버에 설정한 DocumentRoot 경로가 기본 경로와 분리되었는지 여부 점검
점검 목적	웹 서비스 영역 내 불필요한 경로를 분리해 웹 서비스의 침해가 시스템 영역으로 확장될 가능성을 최소화하기 위함
보안 위협	웹 서비스 경로를 기타 업무와 영역이 분리되지 않은 경로로 설정하거나, 불필요한 경로가 존재할 경우 외부에서 시스템 중요 파일이나 기능에 비인가 접근이 발생할 위험이 존재함
참고	-
점검 대상 및 판단 기준	
대상	Apache, Tomcat, Nginx, IIS, JEUS, WebtoB
판단 기준	**양호 :** 웹 서버 경로를 기타 업무와 영역이 분리된 경로로 설정 및 불필요한 경로가 존재하지 않는 경우
	취약 : 웹 서버 경로를 기타 업무와 영역이 분리되지 않은 경로로 설정하거나 불필요한 경로가 있는 경우
조치 방법	웹 서버의 경로를 별도의 경로로 변경 및 불필요한 경로 제거 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

- **Apache**

Step 1) apache2.conf (또는 /conf/httpd.conf) 파일 내 DocumentRoot를 별도의 경로로 변경

```
DocumentRoot [별도의 경로]
```

- **Tomcat**

Step 1) web.xml 파일 내 docBase를 별도의 경로로 변경

```
<Host name="localhost"  appBase="webapps" unpackWARs="true" autoDeploy="true">
  <Context path="" docBase="[별도의 경로]" />
</Host>
```

Nginx

Step 1) sites-available 파일 내 DocumentRoot를 별도의 경로로 변경

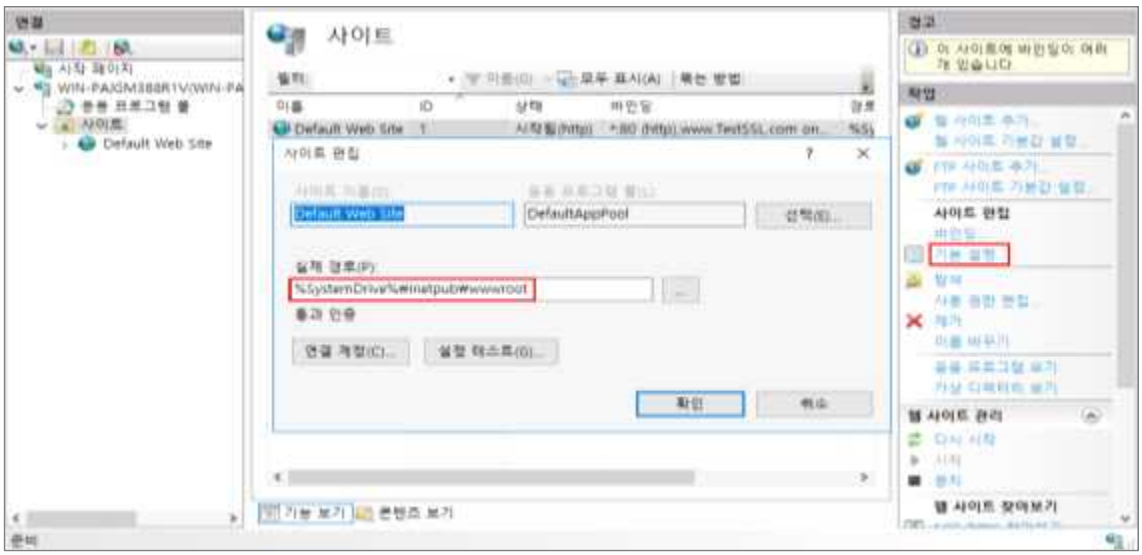
vi /[Nginx 설치 디렉터리]/sites-available

root [별도의 경로]

IIS

Step 1) 기본 디렉터리 확인

시작 > Windows 관리 도구 > 인터넷 정보 서비스(IIS) 관리자 > 해당 웹 사이트 > 사이트 편집 > 기본 설정 > “실제 경로”를 별도의 경로로 변경



[루트 디렉터리 경로 확인]

JEUS

Step 1) ws_engine.m 파일 내 Docroot을 별도의 경로로 변경

Docroot = “[별도의 경로]”

WebtoB

Step 1) http.m 파일 내 DOCROOT를 별도의 경로로 변경

DOCROOT="[별도의 경로]",

WEB-12 (중)	웹 서비스 〉 2. 서비스 관리
	웹 서비스 링크 사용 금지
개요	
점검 내용	웹 서비스 링크(심볼릭 링크, aliases 등) 사용 제한 여부 점검
점검 목적	무분별한 심볼릭 링크, 별칭(aliases) 등을 제거하여 허용하지 않은 경로에서의 접근을 차단해 경로 검증을 우회한 시스템 파일 접근을 방지하기 위함
보안 위협	• 보안상 민감한 내용이 포함되어 있는 파일이 악의적인 사용자에게 노출될 경우 침해사고로 이어질 위험이 존재함 • 접근을 허용한 웹 디렉터리 내에 서버의 다른 디렉터리나 파일들에 접근할 수 있는 심볼릭 링크, aliases, 바로가기 등이 존재하는 경우 해당 링크를 통해 허용하지 않은 다른 디렉터리에 액세스할 수 있는 위험이 존재함
참고	※ **심볼릭 링크(Symbolic link, 소프트 링크):** 사용자가 심볼릭 링크 파일을 요청하면, 시스템이 해당 링크에 저장된 대상 경로를 따라가서 실제 원본 데이터를 가져와 전달
점검 대상 및 판단 기준	
대상	Apache, Tomcat, Nginx, IIS, JEUS, WebtoB
판단 기준	**양호 :** 심볼릭 링크, aliases, 바로가기 등의 링크 사용을 허용하지 않는 경우
	취약 : 심볼릭 링크, aliases, 바로가기 등의 링크 사용을 허용하는 경우
조치 방법	웹 서비스 링크 사용 제한 설정
조치 시 영향	심볼릭 링크를 이용하여 웹페이지가 구성된 경우 해당 서비스가 실행되지 않을 수 있음

점검 및 조치 사례

Apache

Step 1) apache.conf(또는 /conf/httpd.conf) 파일 내 Options 지시자 FollowSymLinks 옵션 제거

```
<Directory />
  Options –FollowSymLinks
  #Options Indexes FollowSymLinks
</Directory>
```

Tomcat

Step 1) server.xml 파일 내 Context 요소 allowLinking 옵션 설정

```
<Context allowLiking="true">
  <WatchedResource>WEB-INF/web.xml</WatchedResource>
  <WatchedResource>WEB-INF/tomcat-web.xml</WatchedResource>
  <WatchedResource>${catalina.base}/conf/web.xml</WatchedResource>
</Context>
```

Nginx

Step 1) nginx.conf 파일 내 설정된 모든 디렉터리의 disable_symlinks on 설정(기본값 : 설정값 없음)

```
location / {
  root   html;
  index  index.html index.htm;
  disable_symlinks on;
}
```

IIS

Step 1) 홈 디렉터리 바로가기 파일 확인

제어판 > 관리 도구 > 인터넷 정보 서비스(IIS) 관리자 > 해당 웹사이트 > 기본 설정 > '실제 경로'로 설정된 경로로 이동 > 바로가기 파일 확인 후 제거

[홈 디렉터리 위치 확인]

JEUS

Step 1) jeus-web-dd.xml 파일 내 alias 요소 설정 제거

```
<aliasing>
  <alias>
    <alias-name>/images/</alias-name>
    <real-path>/home/web/images/</real-path>
  </alias>
</aliasing>
```

WebtoB

Step 1) http.m 파일 내 ALIAS 절 요소 설정 제거

```
# cat /[WebtoB 설치 디렉터리]/config/http.m | grep -C 2 ALIAS
*ALIAS
alias1              URI = "/cgi-bin/", RealPath = "/home/tmax/webtob/cgi-bin/"
```

WEB-13 (상)	웹 서비스 〉 2. 서비스 관리
	웹 서비스 설정 파일 노출 제한
개요	
점검 내용	DB 연결 파일에 대한 접근 권한, 스크립트 매핑 등 웹 서비스에서의 DB 연결 취약점 존재 여부 점검
점검 목적	웹 서비스에서 DB 연결 파일에 대한 접근 권한 제한 및 불필요한 스크립트 매핑을 제거하여, DB 연결 정보(사용자 이름, 비밀번호 등)가 외부에 노출되거나 공격자의 DB 접근 및 관리자 권한 획득 등의 다양한 공격을 방지하기 위함
보안 위협	웹 서비스에서 DB 연결 파일에 대한 접근 권한 제한 및 불필요한 스크립트 매핑을 제거하지 않을 경우, DB 연결 파일에 존재하는 데이터베이스 관련 정보(IP주소, DB명, 비밀번호), 서버 내부 IP주소, 웹 서비스 환경설정 정보 등 보안상 민감한 내용이 악의적인 사용자에게 노출될 위험이 존재함
참고	-
점검 대상 및 판단 기준	
대상	Tomcat, IIS, JEUS
판단 기준	**양호 :** 일반 사용자의 DB 연결 파일에 대한 접근을 제한하고, 불필요한 스크립트 매핑이 제거된 경우
	취약 : 일반 사용자의 DB 연결 파일에 대한 접근을 제한하지 않거나, 불필요한 스크립트 매핑이 제거되지 않은 경우
조치 방법	DB 연결 파일에 대한 접근 권한 제한 또는 불필요한 스크립트 매핑 제거 등을 통한 웹 서비스 내 DB 연결 취약점 제거 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● Tomcat

Step 1) server.xml 파일 내 불필요한 DB 연결 리소스 설정 제거

```
<GlobalNamingResources>
  <Resource name="jdbc/MyDB"
    auth="Container"
    type="javax.sql.DataSource"
    maxTotal="100"
    maxIdle="30"
    maxWaitMillis="10000"
    username="dbuser"
```

password="dbpassword"

driverClassName="com.mysql.jdbc.Driver"

url="jdbc:mysql://localhost:3306/mydb"/>

</GlobalNamingResources>

Step 2) DB 연결 리소스가 존재하는 설정 파일 접근권한을 600으로 설정

chmod 600 /[Tomcat 설치 디렉터리]/conf/server.xml

IIS

Step 1) 처리기 매핑에서 불필요한 DB 매핑 설정 제거

제어판 > 관리 도구 > 인터넷 정보 서비스(IIS) 관리자 > 해당 웹사이트 > IIS > 처리기 매핑 선택, 사용 항목에 *.asa/*.asax 항목 제거

[asa/asax 스크립트 매핑 확인]

Step 2) 요청 필터링에서 DB 매핑 설정제한

"허용됨" 값이 true인 매핑 제거 및 "파일 이름 확장명 거부"에 등록

[asa/asax 파일 필터링 확인]

※ asa/asax 스크립트 매핑 또는 파일 필터링 중 하나라도 설정 시 취약

JEUS

Step 1) 설정 파일 내 불필요 DB 연결 리소스 설정 제거

#vi /[JEUS 설치 디렉터리]/conf/domain.xml

```
<datasource>
  <jndi-name>jdbc/UnnecessaryDB</jndi-name>
  <driver-class>com.example.Driver</driver-class>
  <url>jdbc:example://localhost:1234/unnecessarydb</url>
  <username>user</username>
  <password>password</password>
  <max-connections>10</max-connections>
</datasource>
```

Step 2) 설정 파일의 접근권한을 600으로 설정

chmod 600 /[JEUS 설치 디렉터리]/conf/domain.xml

※ domain.xml 뿐 아니라 개별 웹 서비스의 설정 파일인 jeus-web-dd.xml에서도 삭제 필요

WEB-14 (상)	웹 서비스 〉 2. 서비스 관리
	웹 서비스 경로 내 파일의 접근 통제
개요	
점검 내용	웹 서비스 경로의 파일들에 대해 관리자를 제외한 일반 사용자의 파일 접근 권한 제거 여부 점검
점검 목적	웹 서비스 경로의 파일들에 관리자를 제외한 일반 사용자의 파일 접근 권한을 제거함으로써 인가되지 않은 사용자가 허용되지 않는 파일에 접근하는 것을 차단하기 위함
보안 위협	웹 서비스 경로 파일에 비인가자가 접근 가능한 경우, 해당 파일의 수정 및 삭제로 인해 웹 서비스 운영 장애 및 계정 비밀번호 정보 등의 중요한 정보가 노출될 위험이 존재함
참고	※ 웹 서비스 경로 내 파일/디렉터리에 접근 권한을 허용할 때는 필요한 때에만 설정하고, 필요한 특정 위치의 특정 사용자에게만 허용하도록 조치
점검 대상 및 판단 기준	
대상	Apache, Tomcat, Nginx, IIS, JEUS, WebtoB
판단 기준	**양호 :** 주요 설정 파일 및 디렉터리에 불필요한 접근 권한이 부여되지 않은 경우
	취약 : 주요 설정 파일 및 디렉터리에 불필요한 접근 권한이 부여된 경우
조치 방법	주요 설정 파일 및 디렉터리에 불필요한 접근 권한 제거 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● Apache

Step 1) 루트 디렉터리 내 불필요한 권한 삭제 또는 적절한 권한 부여

```
# chown –R <Apache 계정>]:<Apache 그룹> apache2.conf (또는 httpd.conf)
# chmod -R 750 apache2.conf (또는 httpd.conf)
```

● Tomcat

Step 1) 루트 디렉터리 불필요한 권한 삭제 또는 적절한 권한 부여

```
# chown –R [Tomcat 계정]:[Tomcat 그룹] web.xml
# chmod -R 750 web.xml
```

Nginx

Step 1) 루트 디렉터리 불필요한 권한 삭제 또는 적절한 권한 부여

chown –R <Nginx 계정>:<Nginx 그룹> web.xml

chmod -R 750 web.xml

IIS

Step 1) 실제 경로 디렉터리 내 불필요한 권한 삭제 또는 적절한 권한 부여

web.config > 속성 > 보안 > 편집 > "그룹 또는 사용자 이름"의 불필요 권한 제거

[설정 파일 권한 확인]

JEUS

Step 1) 루트 디렉터리 불필요한 권한 삭제 또는 적절한 권한 부여

chown –R <Jeus 계정>:<Jeus 그룹> accounts.xml

chmod -R 750 accounts.xml

WebtoB

Step 1) 루트 디렉터리 불필요한 권한 삭제 또는 적절한 권한 부여

chown –R <WebtoB 계정>:<WebtoB 그룹> http.m

chmod -R 750 http.m

WEB-15 (상)	웹 서비스 〉 2. 서비스 관리
	웹 서비스의 불필요한 스크립트 매핑 제거
개요	
점검 내용	웹 서비스 내 불필요 스크립트 매핑 제거 여부 점검
점검 목적	웹 서비스에서 사용하지 않는 불필요 스크립트 매핑이 존재하는지 점검하여 잠재적 보안 위협을 방지하기 위함
보안 위협	웹 서비스에서 불필요한 스크립트 매핑을 제거하지 않은 경우, 버퍼 오버플로우(Buffer Overflow), 서비스 거부 공격(Denial of Service), 크로스 사이트 스크립팅(Cross Site Scripting) 등의 공격 위험이 존재함
참고	※ .asp나 .shtm과 같은 확장자들은 특정 DLL 파일과 매핑되어 있어, 이러한 파일들에 대한 요청이 들어오면 해당 DLL에 의해 처리됨 ※ **스크립트 매핑:** 웹 서버에서 특정 파일 확장자나 URL 경로를 특정 스크립트 처리프로그램에 연결하는 설정
점검 대상 및 판단 기준	
대상	Tomcat, IIS, JEUS
판단 기준	**양호 :** 불필요한 스크립트 매핑이 존재하지 않는 경우
	취약 : 불필요한 스크립트 매핑이 존재하는 경우
조치 방법	불필요한 스크립트 매핑 존재 여부 점검 및 제거 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● Tomcat

Step 1) 설정 파일의 불필요 스크립트 매핑 제거

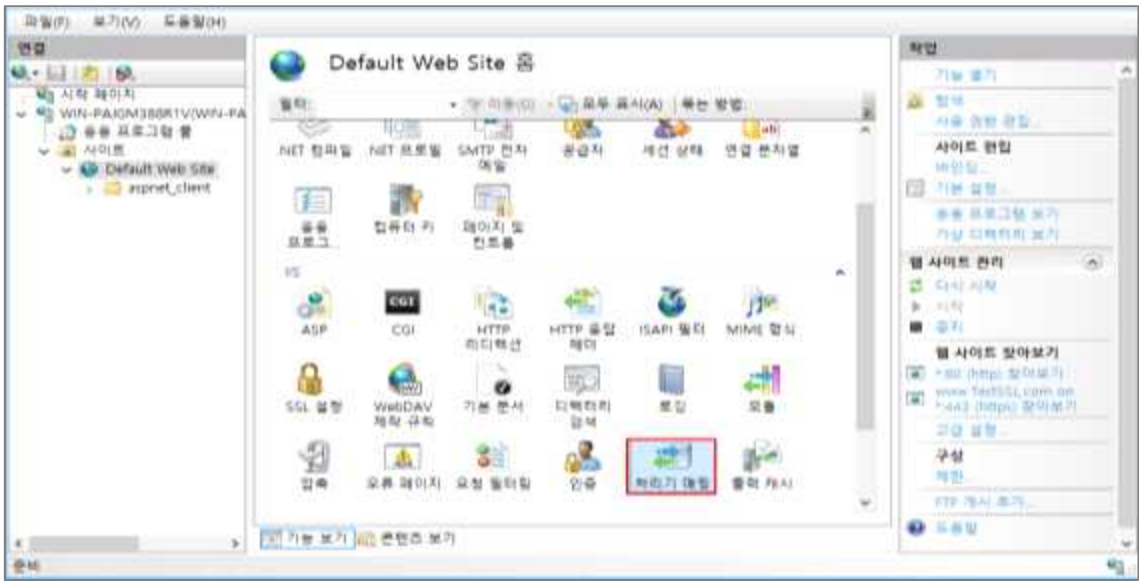
```
<servlet-mapping>
  <servlet-name>UnuseServlet</servlet-name>
  <url-pattern>/example/*</url-pattern>
</servlet-mapping>
```

※ context.xml 파일 내 명시된 설정 파일에서도 DB 연결 확인 필요

IIS

Step 1) 취약한 매핑 설정 확인(.htr, .idc, .stm, .shtm, .shtml, .printer, .htw, .ida, .idq)

시작 > 실행 > INETMGR > 웹사이트 > 해당 웹사이트 > '처리기 매핑' 선택 후 미사용 확장자 매핑 설정 제거



[웹사이트의 처리기 매핑]

확장자명	기능	취약점
asp	Active Server Pages 기능 지원	Buffer Overflow MS02-018 • Win 2000 SP3 이상 양호
htr	Web-based password reset: Outlook Web Access 등에서 웹 기반 응용, 프로그램으로 자신의 사용자 계정 암호 변경	.htr 소스 공개 취약점 MS01-004 • Win 2000 SP3, NT SP 7.0 이상 양호
idc	Internet Database Connector: SQL 서버에 연결하기 위한 정보 등을 관리하며, asp를 통해 같은 작업을 수행 가능	Web 디렉터리 패스 공개 Q193689 • NT4.0, NT SP6a이상 양호
stm, stml, shtml	Server-Side Includes	Buffer Overflow MS01-044 • Win 2000 SP3 이상 양호
printer	Internet Printing: URL을 사용하여 페이지를 프린터로 인쇄할 수 있도록 함 IIS가 인터넷이나 인트라넷을 통해 인쇄 서버 기능 수행	Buffer Overflow MS01-023 • Win 2000 SP2 이상 양호
ida, idq	Index Server: idq.dll에 매핑되며 인덱스 서버 쿼리 시 사용	Buffer Overflow MS01-033 • Win 2000 SP3 이상 양호
htw	Index Server: webhits.dll에 매핑되며, 인덱스 서버 쿼리 시 사용	Webhit 소스 공개 취약점 MS00-006 • Win 2000 SP1 이상 양호

JEUS

Step 1) web.xml 파일 내 <servlet-mapping> 요소에서 불필요 매핑 확인

```
<servlet-mapping>
  <url-pattern>/welcome</url-pattern>
  <servlet-name>jsp</servlet-name>
</servlet-mapping>
```

WEB-16 (중)	웹 서비스 〉 2. 서비스 관리
	웹 서비스 헤더 정보 노출 제한
개요	
점검 내용	웹페이지 응답 헤더에서 버전 정보, 사용 중인 OS 등의 서버 정보 노출 여부 점검
점검 목적	HTTP 응답 헤더에서 웹 서버 버전 및 종류, OS 정보 등 웹 서버와 관련된 정보가 불필요하게 노출되는 것을 최소화하기 위함
보안 위협	웹 서버 및 OS 정보가 노출될 경우 공격자에 의해 해당 버전의 알려진 취약점을 이용하여 시스템 구조와 특성 노출 및 해당 취약점을 통한 공격의 위험이 존재함
참고	-
점검 대상 및 판단 기준	
대상	Apache, Tomcat, Nginx, IIS, JEUS, Webtob
판단 기준	**양호 :** HTTP 응답 헤더에서 웹 서버 정보가 노출되지 않는 경우
	취약 : HTTP 응답 헤더에서 웹 서버 정보가 노출되는 경우
조치 방법	응답 헤더에 표시되는 정보를 최소한으로 제한하여 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

- **Apache**

Step 1) httpd.conf (또는 apache2.conf) 파일 내 모든 디렉터리에 ServerTokens, ServerSignature 옵션 설정

```
<Directory/>
  ServerTokens Prod
  ServerSignature Off
</Directory>
```

※ ServerTokens 지시자 옵션

ServerTokens 지시자 옵션		
키워드	제공하는 정보	예문
Prod	웹 서버 종류	Apache
Min	웹 서버 버전	Apache/2.2.3
OS	웹 서버의 버전 + 운영체제	Apache/2.2.3 (CentOS) 기본값
Full	웹 서버의 모든 정보	Apache/2.2.3 (CentOS) DAV/2 PHP/5.16

Tomcat

Step 1) server.xml 파일 내 server 값을 임의 정보로 변경

```
〈Connector port="8080" protocol="HTTP/1.1"
connectionTimeout="20000"
redirectPort="8443"
server="{임의 정보로 변경}“
/〉
```

Step 1) server.xml 파일 내 아래 내용 추가

```
〈Host〉
... 중략 ...
〈Valve className="org.apache.catalina.valves.ErrorReportValve" showReport="true" showServerInfo
="false"/〉
... 중략 ...
〈/Host〉
```

Nginx

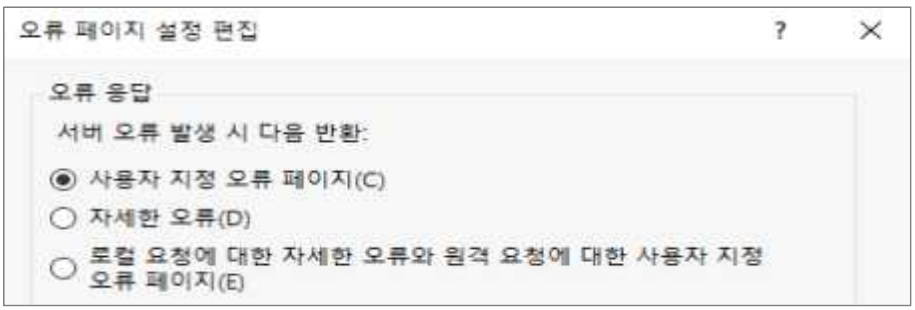
Step 2) nginx.conf 파일 내 server_tokens 값을 “off”로 설정

server_tokens off;

IIS

Step 1) 오류 페이지 설정 편집

제어판 > 관리 도구 > IIS(인터넷 정보 서비스) 관리자 > 해당 웹 사이트 > [오류 페이지] > [작업] 탭에서 [기능 설정 편집] > “서버 오류 발생 시 다음 반환” 항목을 “사용자 지정 오류 페이지”로 설정



[오류 페이지 설정 편집]

JEUS

[jeus 7 이전 버전]

Step 1) JEUSMain.xml 파일 내 아래 내용 추가

```
〈jeus-system〉
〈node〉
... 중략 ...
〈engine-container〉
... 중략 ...
〈command-option〉-Djeus.servlet.response.header.serverInfo=false〈/command-option〉
〈/engine-container〉
... 중략 ...
〈/node〉
〈/jeus-system〉
```

[jeus 7]

Step 2) domain.xml 파일 내 아래 내용 추가

```
〈response-header〉
 〈custom-header〉
  〈header-field〉
   〈field-name〉P3P〈/field-name〉
   〈field-value〉CP='CAO PSA CONi OTR OUR DEM ONL'〈/field-value〉
  〈/header-field〉
 〈/custom-header〉
〈/response-header〉
```

WebtoB

Step 1) Server 설정 파일 내부 지시자 확인(기본값: off)

cat /[WebtoB 설치 디렉터리]/config/http.m | grep –i “ServerTokens”

Step 2) 설정 파일 내부 지시자 옵션 설정

vi /[WebtoB 설치 디렉터리]/config/http.m

ServerTokens ProductOnly(Prod)

ServerSignature off // Off : Response Header에 server 필드를 사용하지 않음

Step 3) ServerTokens 옵션별 반환 정보

구분	반환되는 헤더 정보
Prod[uctOnly]	WebtoB
Min[imal]	WebtoB/4.1.3
OS	WebtoB/4.1.3 LINUX-K2.6_x86 libc2.3
Full	WebtoB/4.1.3 LINUX-K2.6_x86 libc2.3
Custom	user-specified-name

WEB-17 (중)	웹 서비스 〉 2. 서비스 관리
	웹 서비스 가상 디렉로리 삭제
개요	
점검 내용	불필요한 가상 디렉터리 삭제 여부 점검
점검 목적	불필요한 가상 디렉터리를 삭제하여 공격이 가능한 영역을 최소화하고 정보 노출 방지 및 권한 상승 공격 등의 위험을 제거하기 위함
보안 위협	불필요한 가상 디렉터리를 삭제하지 않은 경우, 취약한 가상 디렉터리를 통해 시스템 권한 탈취 및 시스템 구조 등의 중요 정보가 노출될 위험이 존재함
참고	※ **가상 디렉터리:** 물리적으로 홈 디렉터리와 다른 위치에 있거나 홈 디렉터리에 종속된 디렉터리가 아니어도 웹 브라우저를 통해 사용자가 접속할 때 웹사이트의 하위 디렉터리로 인식되도록 하는 기법
점검 대상 및 판단 기준	
대상	Apache, Tomcat, Nginx, WebtoB
판단 기준	**양호 :** 불필요한 가상 디렉터리가 존재하지 않는 경우
	취약 : 불필요한 가상 디렉터리가 존재하는 경우
조치 방법	불필요한 가상 디렉터리 존재 여부 점검 및 삭제하도록 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● Apache

Step 1) Alias 지시자 확인

```
# vi /[Apache 설치 디렉터리]/conf/httpd.conf(또는 apache2.conf)
Alias /virtual /var/www/virtual
<Directory /var/www/virtual>
  Options Indexes FollowSymLinks
  AllowOverride None
  Require all granted
</Directory>
```

Step 2) 불필요한 가상 디렉터리 삭제

Tomcat

Step 1) 'Context' 블록 요소의 'path' 속성값 확인

#vi /[Tomcat 설치 디렉터리]/server.xml

<Host name="localhost" appBase="webapps" unpackWARs="true" autoDeploy="true">

  <Context path="/virtual" docBase="/path/to/your/virtual/directory" reloadable="true"/>

</Host>

Step 2) Context 블록 요소 가상 디렉터리 제거

Nginx

Step 1) Alias 지시자 확인

vi /[Nginx Dir]/nginx –v

location /virtual {

alias /var/www/virtual;

index index.html index.htm;

}

Step 2) 설정된 모든 디렉터리의 불필요한 Alias 지시자 제거

Step 3) Nginx 재구동

systemctl restart nginx

WebtoB

Step 1) NODE절의 Alias 설정 확인

vi /[WebtoB 설치 디렉터리]/config/http.m

*ALIAS

alias1 URI = "/cgi-bin/", RealPath = "/home/tmax/webtob/cgi-bin/"

Step 2) NODE절의 불필요한 Alias 설정 삭제

WEB-18 (상)	웹 서비스 〉 2. 서비스 관리
	웹 서비스 WebDAV 비활성화
개요	
점검 내용	웹 서비스 WebDAV 비활성화 여부 점검
점검 목적	WebDAV 서비스를 비활성화하여, WebDAV에서 발견되는 다수의 인증 우회 취약점을 제거하고자 함
보안 위협	WebDAV가 활성화되어 있는 경우 웹 서비스에 악의적으로 작성된 요청을 이용하여 인증을 우회함으로써 비밀번호로 보호된 WebDAV의 자원에 접근 (디렉터리 열람, 파일 다운로드 등)이 가능하며, WebDAV에 의해 호출된 일부 구성요소에 매개 변수를 정확하게 점검하지 않는 결함이 존재하여, 이로 인해 버퍼 오버런이 발생할 위험이 존재함
참고	※ **WebDAV(Web Distributed Authoring and Versioning):** 사용자가 원격 World Wide Web 서버를 이용하여 파일을 수정하거나 처리할 수 있도록 하는 HTTP의 확장 서비스. 웹상의 공동개발을 지원하기 위한 IETF 표준안(RFC 2518)으로써, 원격지 사용자 간에 인터넷상에서 파일을 공동 편집하고 관리할 수 있도록 함
점검 대상 및 판단 기준	
대상	Apache, Nginx, IIS, WebtoB
판단 기준	**양호 :** WebDAV 서비스를 비활성화하고 있는 경우
	취약 : WebDAV 서비스를 활성화하고 있는 경우
조치 방법	WebDAV 서비스 비활성화 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● Apache

Step 1) httpd.conf 파일 내 모든 디렉터리에서 WebDAV 설정 확인

```
# cat /[Apache_Dir]/conf/httpd.conf(또는 apache2.conf)
Dav On
```

Step 2) 모든 디렉터리에서 WebDAV 설정 비활성화 또는 주석 처리

```
# vi /[Apache_Dir]/conf/httpd.conf(또는 apache2.conf)
<Directory "/path/to/directory">
  Dav Off
</Directory>
```

Step 3) Apache 재구동

```
# systemctl restart apache2
```

Nginx

Step 1) nginx.conf 파일 내 모든 디렉터리에서 WebDAV 설정 확인

```
# cat /[Nginx 설치 디렉터리]/conf/nginx.conf
location /webdav {
  root /path/to/webdav;
  dav_methods PUT DELETE MKCOL COPY MOVE;
  dav_access user:rw group:rw all:r;
  create_full_put_path on;
}
```

Step 2) nginx.conf 파일 내 모든 디렉터리에서 WebDAV 설정 주석 처리 또는 제거

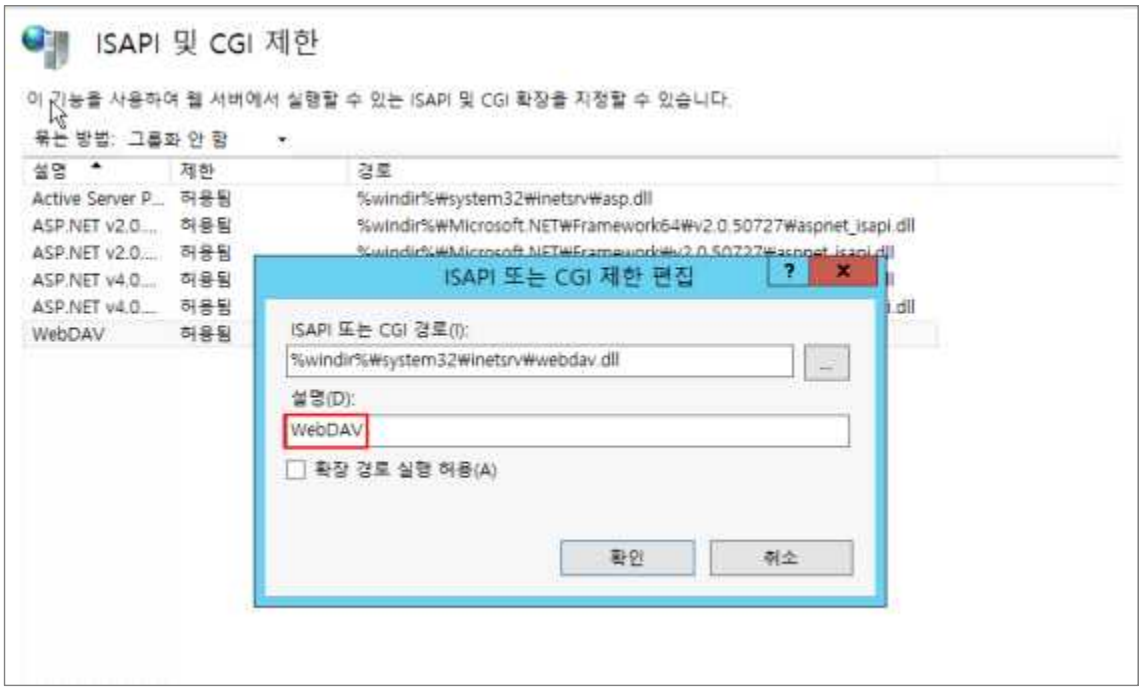
Step 3) Nginx 재구동

```
# systemctl restart nginx
```

IIS

Step 1) WebDAV 금지 설정 확인

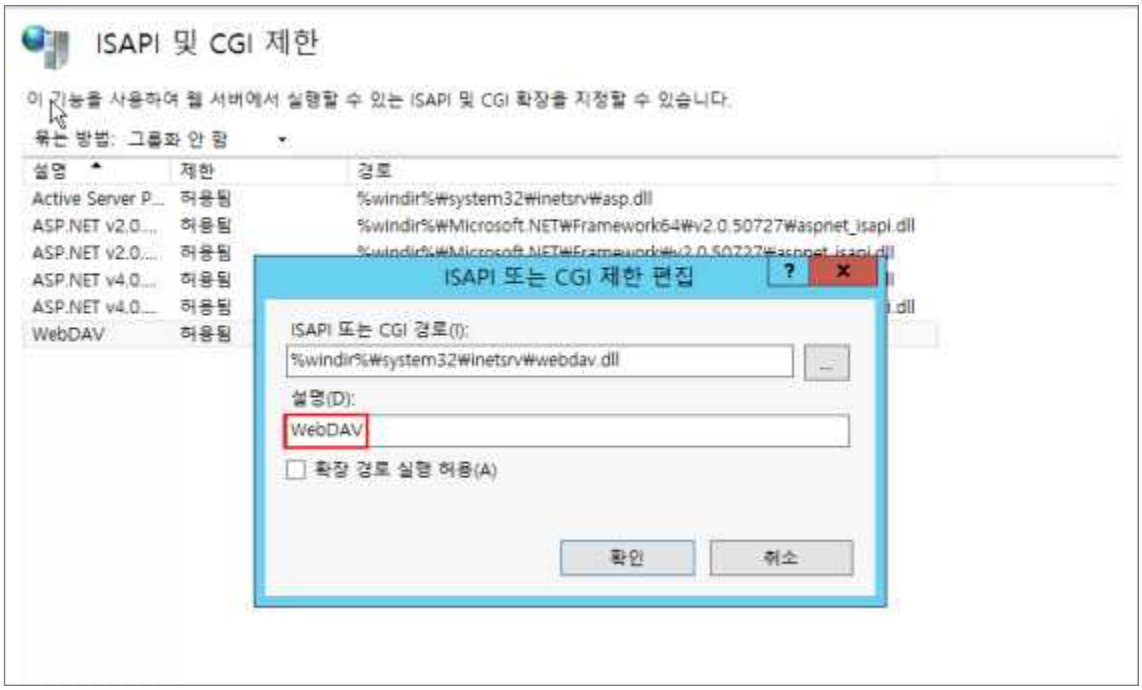
제어판 > 관리 도구 > 인터넷 정보 서비스(IIS) 관리자 > 서버 선택 > IIS > 'ISAPI 및 CGI 제한' 선택, WebDAV 항목 선택 > '확장 경로 실행 허용(A)' 체크 확인



[WebDAV 제한 설정]

Step 2) WebDAV 금지 설정 확인

제어판 > 관리 도구 > 인터넷 정보 서비스(IIS) 관리자 > 서버 선택 > IIS > ‘ISAPI 및 CGI 제한’ 선택, WebDAV 항목 선택 > [작업]에서 제거하거나, 편집 > ‘확장 경로 실행 허용(A)’ 체크 해제



[WebDAV 제한 설정]

WebtoB

Step 1) Server 설정 파일 내 NODE절 vhost 메소드 설정 확인

vi /[WebtoB 설치 디렉터리]/config/http.m

*VHOST

vhost1 .

Method = “GET, POST, HEAD, OPTIONS, PROPFIND, PUT, DELETE, MKCOL, COPY, MOVE”

Step 2) NODE절 WebDAV 설정 삭제

WEB-19 (중)	웹 서비스 〉 3. 보안 설정
	웹 서비스 SSI(Server Side Includes) 사용 제한
개요	
점검 내용	웹 서비스 SSI 사용 제한 설정 여부 점검
점검 목적	웹 서비스 내 SSI 사용을 제한하여 불법적인 데이터 접근을 차단하여 웹 서버의 보안을 강화하기 위함
보안 위협	• 웹 서비스 내 SSI 사용을 제한하지 않을 경우, 공격자가 SSI 기능을 이용하여 시스템 명령 실행 및 중요 파일 탈취 등 공격이 가능하며, 이를 통해 서버 시스템 침해, 데이터 유출 등이 발생할 위험이 존재함 • SSI 공격 시 HTML 페이지에 스크립트를 삽입하거나 원격으로 코드를 실행하여 웹 서비스를 악용할 위험이 존재함
참고	※ SSI(Server-Side Includes): CGI 프로그램을 작성하거나 혹은 서버 사이드 스크립트를 사용하는 언어로, 웹 서버가 사용자에게 페이지를 제공하기 전에 구문을 해석하도록 지시하는 역할을 함 ※ SSI(Server-Side Includes) Injection: HTML 문서 내 입력받은 변수값을 서버 측에서 처리할 때 부적절한 명령문이 포함 및 실행되어 서버의 데이터가 유출되는 취약점
점검 대상 및 판단 기준	
대상	Apache, Tomcat, Nginx, IIS, WebtoB
판단 기준	**양호 :** 웹 서비스 SSI 사용 설정이 비활성화되어 있는 경우
	취약 : 웹 서비스 SSI 사용 설정이 활성화되어 있는 경우
조치 방법	웹 서비스 내 불필요한 SSI 사용 제한 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● Apache

Step 1) Options 지시자 Includes 옵션 확인

```
# vi /[Apache 설치 디렉터리]/conf/httpd.conf(또는 /conf/apache.conf)
<Directory />
  Options Includes
</Directory>
```

Step 2) Options 지시자 Includes 옵션 제거

```
# vi /[Apache 설치 디렉터리]/conf/httpd.conf(또는 /conf/apache.conf)
<Directory />
  Options
</Directory>
```

Tomcat

Step 1) web.xml 파일 내 SSI 서블릿 또는 필터 사용 설정 확인

```
#cat /[Tomcat 설치 디렉터리]/tomcat-users.xml | grep 'SSIServlet\|SSIFilter'
<servlet-mapping>
  <servlet-name>SSIServlet</servlet-name>
  <url-pattern>*.shtml</url-pattern>
</servlet-mapping>
```

또는

```
<filter-mapping>
  <filter-name>SSIFilter</filter-name>
  <url-pattern>*.shtml</url-pattern>
</filter-mapping>
```

Step 2) web.xml 파일 내 SSI 서블릿 및 필터 설정 삭제 또는 주석 처리

Step 3) web.xml 파일 내에서 SSI와 관련한 불필요 mapping 제거 또는 주석 처리

Step 4) Tomcat 서비스 재구동

```
# systemctl restart tomcat
```

Nginx

Step 1) nginx.conf 파일 내 SSI 옵션 사용 여부 확인

```
# cat /[Nginx 설치 디렉터리]/conf/nginx.conf
location / {
  ssi on;
}
```

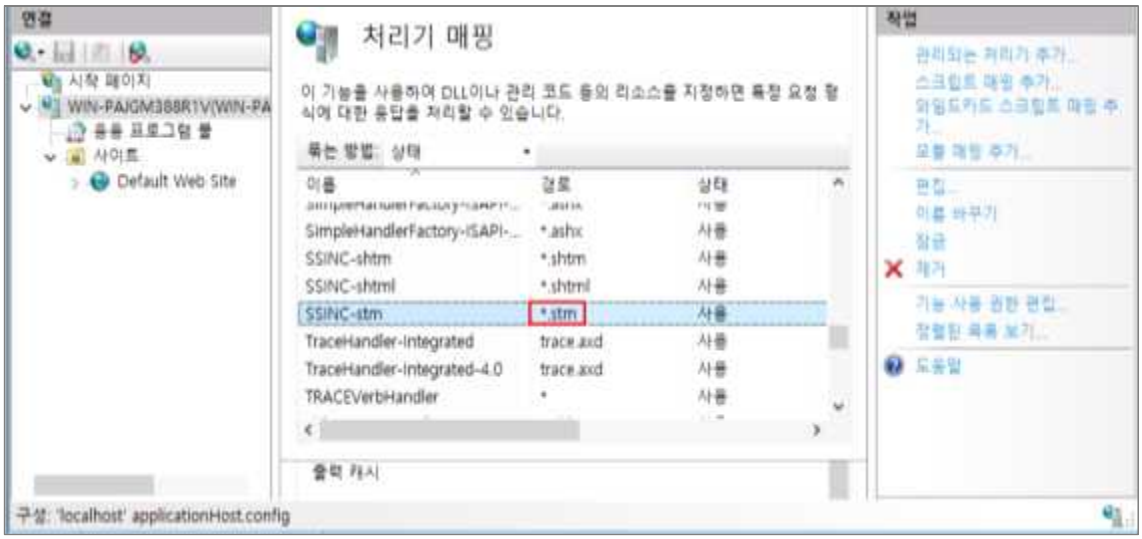
Step 2) nginx.conf 파일 내 모든 디렉터리의 SSI 옵션 설정

```
# vi /[Nginx 설치 디렉터리]/conf/nginx.conf
location / {
  ssi off;
}
```

IIS

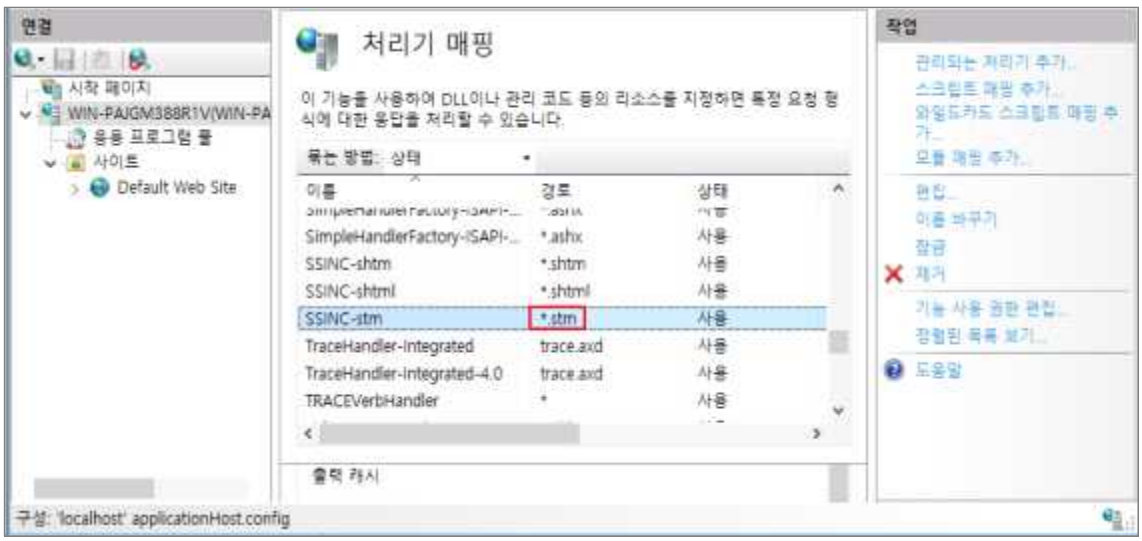
Step 1) 매핑 확장자 확인

인터넷 정보 서비스(IIS) 관리자 > 서버 선택 > IIS > “처리기 매핑” 선택, .shtml, .shtm, .stm 확장자 매핑 확인(존재할 경우 취약)



[처리기 매핑 확장자 확인]

Step 2) .shtml, .shtm, .stm과 매핑되는 항목 제거



[처리기 확장자 삭제]

WebtoB

Step 1) http.m 파일 내 SSI 서버 연결 설정 확인

```
# vi /[WebtoB 설치 디렉터리]/conf/http.m
*SVRGROUP
ssig        NodeName = mynode, SvrType = SSI

*SERVER
ssi         SvgName = ssig, MinProc = 10, MaxProc = 10
```

Step 2) SSI 서버 설정 삭제

WEB-20 (상)	웹 서비스 〉 3. 보안 설정
	SSL/TLS 활성화
개요	
점검 내용	서버와 클라이언트 간 통신 시 데이터 암호화 전송 여부 점검
점검 목적	서버와 클라이언트 간 통신 시 데이터의 평문 전송을 사용하지 않고 데이터가 암호화되는 SSL/TLS 인증 암호화 접속을 통해 스니핑을 통한 정보 유출의 위험을 방지하기 위함
보안 위협	• 웹상의 데이터 통신 시 서버와 클라이언트 간에 데이터를 평문 전송하는 경우, 간단한 도청(스니핑)을 통해 정보가 탈취 및 도용될 위험이 존재함 • SSL/TLS가 활성화되어 있지 않을 경우, 데이터는 암호화되지 않아 공격자가 중간에서 데이터를 가로채거나 도청할 수 있으며, 더 나아가 평문으로 전송되어 중간에서 변경될 우려가 있어 데이터의 정확성이 훼손될 위험이 존재함
참고	※ **스니핑(임의 지정):** 스니퍼(Sniffer)는 "컴퓨터 네트워크상에 흘러 다니는 트래픽을 엿듣는 도청장치"라고 말할 수 있으며 "스니핑"이란 이러한 스니퍼를 이용하여 네트워크상의 데이터를 도청하는 행위를 말함 ※ **SSL(Secure Socket Layer):** 인터넷상에서 정보를 암호화하여 송/수신하는 프로토콜. 현재 인터넷에서 널리 쓰이고 있는 www, FTP 등의 데이터를 암호화하여, 프라이버시에 관한 정보나 신용카드 번호, 기업 비밀 등을 안전하게 송/수신할 수 있음
점검 대상 및 판단 기준	
대상	Apache, Nginx, IIS, WebtoB
판단 기준	**양호 :** SSL/TLS 설정이 활성화되어 있는 경우
	취약 : SSL/TLS 설정이 비활성화되어 있는 경우
조치 방법	웹 서비스 내 SSL/TLS 활성화 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● Apache

Step 1) SSL 모듈 활성화 확인

```
# apache2ctl –M | grep ssl
ssl_module (shared)
```

Step 2) SSL 가상 호스트 설정에 SSL 인증서 설정 추가

```
# vi /[Apache 설치 디렉터리]/sites-available/default-ssl.conf
<VirtualHost *:443>
```

```
    ServerAdmin webmaster@yourdomain.com
    ServerName yourdomain.com
    DocumentRoot /var/www/html
    SSLEngine on
    SSLCertificateFile /path/to/your_domain_name.crt
    SSLCertificateKeyFile /path/to/your_domain_name.key
    ErrorLog ${APACHE_LOG_DIR}/error.log
    CustomLog ${APACHE_LOG_DIR}/access.log combined
</VirtualHost>
```

Step 3) SSL 가상 호스트 활성화

```
# a2ensite default-ssl
```

Step 4) Apache 재구동

```
# systemctl restart apache2
```

- **Nginx**

Step 1) SSL 인증서 파일 및 개인키 파일 준비

Step 2) nginx.conf 파일 내 SSL/TLS 설정

```
# vi /[Nginx 설치 디렉터리]/conf/nginx.conf
server {
  listen 80;
  server_name example.com;
  location / {
    return 301 https://$host$request_uri;
  }
}

server {
  listen 443 ssl;
  server_name example.com;
  ssl_certificate /etc/letsencrypt/live/example.com/fullchain.pem;
  ssl_certificate_key /etc/letsencrypt/live/example.com/privkey.pem;
```

```
    ssl_protocols TLSv1.2 TLSv1.3;
    ssl_prefer_server_ciphers on;
    ssl_ciphers 'SSL_CIPHERS';
    }
}
```

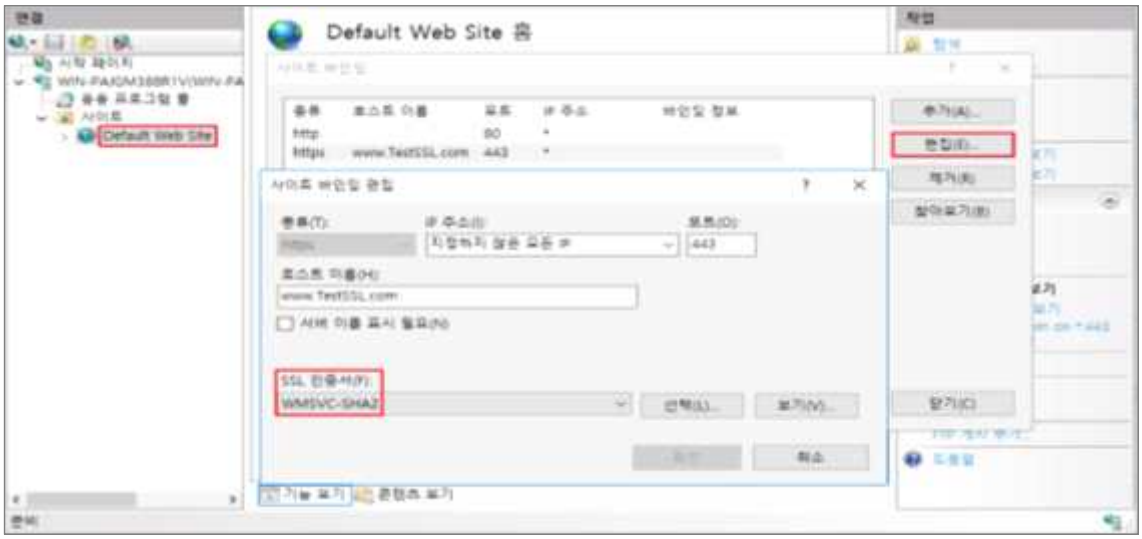
Step 3) Nginx 재구동

```
# systemctl restart nginx
```

● IIS

Step 1) SSL 인증서 바인딩 설정

제어판 > 관리 도구 > IIS(인터넷 정보 서비스) 관리자 > 해당 웹사이트 > [사이트 바인딩] > [편집] 탭 > SSL 인증서 확인



[SSL 인증서 확인]

Step 2) SSL 인증서 가져오기

발급받은 인증서 > 인증서 설치 > '로컬 컴퓨터'선택 > 다음 > '인증서 종류를 기준으로 인증서 저장소를 자동으로 선택' 선택 > 다음 > 마침

Step 3) SSL 인증서 설치

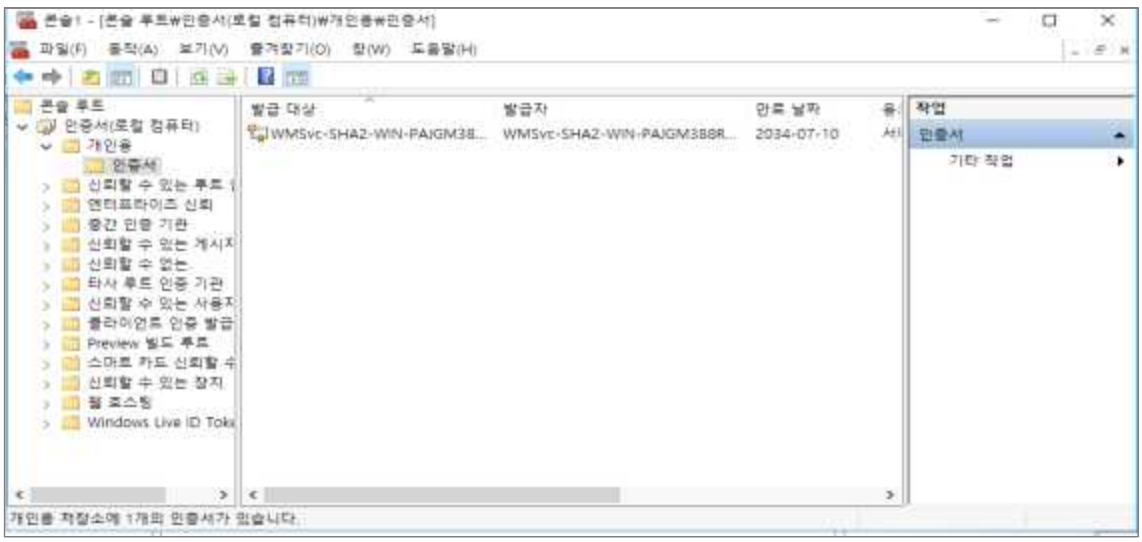
C:\Windows\System32\mmc.exe > 파일 > 스냅인 추가/제거 > 인증서 > 추가 > 이 스냅인이 항상 관리할 인증서 대상 '컴퓨터 계정' > 로컬 컴퓨터 > 확인

[SSL 인증서 추가 과정 1]

[SSL 인증서 추가 과정 2]

Step 4) 추가된 인증서 확인

콘솔 루트 > 인증서(로컬 컴퓨터) > 개인용 > 인증서 > 발급된 인증서 확인



[추가된 인증서 확인]

Step 5) 인증서 등록

인터넷 정보 서비스(IIS) 관리자 > 서버 선택 및 우클릭 > “바인딩 편집” 선택 > 추가 > 종류 “https”, IP주소, 포트, 호스트 이름, SSL 인증서 선택 > 확인

Step 6) IIS 서버 재구동

WebtoB

Step 1) http.m 파일 내 SSLFlag, SSLName 설정 확인

```
# vi  /[WebtoB 설치 디렉터리]/config/http.m
*VHOST
vhost1                  ...
        ERRORDOCUMENT   = "400,401,403,404,405,406,503",
        SSLFLAG         = Y,
        SSLNAME         = "ssl_nxcore",
        LOGGING         = "acc_https",
```

Step 2) http.m 파일 내 인증서 설정 파일 확인

```
*SSL
ssl_nxcore          CertificateFile       = "/sw/webtob5/ssl/2023/cert.crt",
                    CertificateKeyFile    = "/sw/webtob5/ssl/2023/privkey.key",
                    CertificateChainFile  = "/sw/webtob5/ssl/2023/chain.crt",
                    CACertificateFile     = "/sw/webtob5/ssl/2023/rootca.crt",
                    PassPhraseDialog      = "file:/sw/webtob5/ssl/passwd",
                    Protocols             = "-SSLv2, -SSLv3, -TLSv1, -TLSv1.1, TLSv1.2, TLSv1.3",
                    RequiredCiphers       = "HIGH:!RSA:!SHA1"
```

Step 3) CA 인증서 및 개인키를 생성해 WebtoB 설정 파일에 설정

WEB-21 (중)	웹 서비스 〉 3. 보안 설정
	HTTP 리디렉션
개요	
점검 내용	웹 서비스 접근 시 HTTP Redirection 활성화 여부 점검
점검 목적	HTTP 차단 및 HTTPS로 Redirection 활성화를 통해 평문으로 전송되는 데이터를 암호화하여 공격자의 데이터 스니핑에 대비하기 위함
보안 위협	HTTP 통신은 암호화 전송이 아닌 평문 전송을 하므로 공격자가 스니핑을 시도할 경우 관리자의 ID, 비밀번호가 노출되어 악의적 사용자가 관리자 계정을 탈취할 수 있는 위험이 존재함
참고	-
점검 대상 및 판단 기준	
대상	Apache, Nginx, IIS, WebtoB
판단 기준	**양호 :** HTTP 접근 시 HTTPS Redirection이 활성화된 경우
	취약 : HTTP 접근 시 HTTPS Redirection이 비활성화된 경우
조치 방법	HTTP Redirection 활성화 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

- Apache

Step 1) SSL 모듈 활성화 확인

```
# apache2ctl -M | grep ssl
```

Step 1) SSL 인증서 활성화 설정

Step 2) (미설치 시) mod_rewrite 설치

```
# apt install mod_ssl
```

Step 3) HTTP Redirection 설정 확인

```
# vi /[Apache 설치 디렉터리]/sites-available/default-ssl.conf
<VirtualHost *:80>
  ServerName example.com
  Redirect permanent / https://example.com/
</VirtualHost>
```

Step 4) SSL 가상 호스트 설정

```
# vi /[Apache 설치 디렉터리]/sites-available/default-ssl.conf
<VirtualHost *:80>
  ServerAdmin webmaster@yourdomain.com
  ServerName yourdomain.com
  DocumentRoot /var/www/html
  RewriteEngine On
  RewriteCond %{HTTPS} off
  RewriteRule ^ https://%{HTTP_HOST}%{REQUEST_URI} [L,R=301]
  ErrorLog ${APACHE_LOG_DIR}/error.log
  CustomLog ${APACHE_LOG_DIR}/access.log combined
</VirtualHost>
```

Step 5) SSL 가상 호스트 활성화 및 Apache 재구동

```
# vi sudo a2ensite default-ssl
# systemctl restart apache2
```

- **Nginx**

Step 1) Server 블록 내 HTTPS Redirection 설정 확인

```
# vi /[Nginx 설치 디렉터리]/sites-available/default
server {
        listen 80;
        server_name yourdomain.com www.yourdomain.com;
        return 301 https://$host$request_uri;
}
```

Step 2) SSL 활성화 설정

```
# vi /[Nginx 설치 디렉터리]/sites-available/default
server {
        listen 80;
        server_name mydomain.com www.mydomain.com;
        return 301 https://$host$request_uri;
}
```

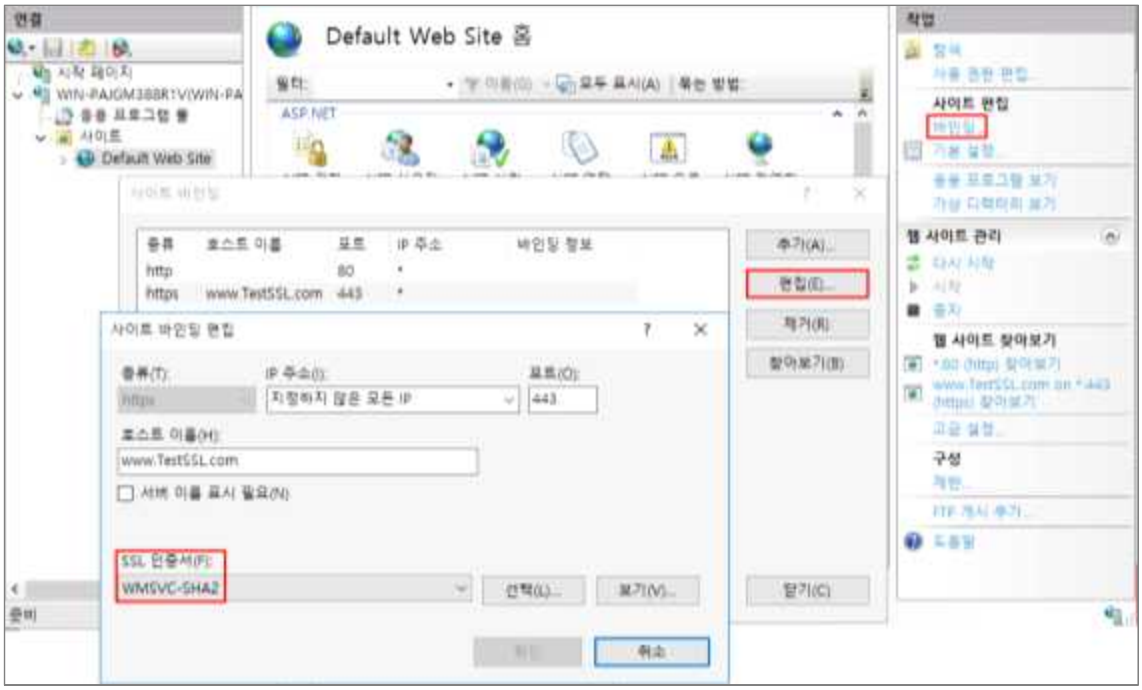
Step 3) Nginx 재구동

systemctl restart nginx

IIS

Step 1) SSL 인증서 활성화

SSL 인증서 등록 과정에서 사이트 바인딩 '종류'를 HTTPS로 설정



[사이트 바인딩 확인]

Step 2) 등록된 SSL 인증서 바인딩 설정 확인

제어판 > 관리 도구 > IIS(인터넷 정보 서비스) 관리자 > 해당 웹사이트 > [사이트 바인딩] > [편집] 탭 > SSL 인증서 확인

Step 3) IIS 서버 재구동

WebtoB

Step 1) Server 설정 파일 NODE절 vhost의 URLRewrite, URLRewriteConfig 설정 확인

vi /[WebtoB 설치 디렉터리]/config/http.m

*VHOST

vhost1 ...

URLRewrite = Y,

URLRewriteConfig = "config/rewrite_ssl.conf",

Step 2) Server 설정 파일 NODE절 vhost의 URLRewrite, URLRewriteConfig 설정

```
# vi /[WebtoB 설치 디렉터리]/config/http.m
*VHOST
vhost1                ...
        URLRewrite = Y,
        URLRewriteConfig = "config/rewrite_ssl.conf",
```

Step 3) URLRewriteConfig 파일에서 Redirection 확인

```
# vi /[WebtoB 설치 디렉터리]/config/rewrite_ssel.conf
RewriteCond %{HTTPS} off
RewriteRule .* https://%{SERVER_NAME}%{REQUEST_URI} [R=307,L]
```

Step 4) URLRewriteConfig 파일에서 Redirection 설정

```
# vi /[WebtoB 설치 디렉터리]/config/rewrite_ssel.conf
RewriteCond %{HTTPS} off
RewriteRule .* https://%{SERVER_NAME}%{REQUEST_URI} [R=307,L]
```

Step 5) 설정 파일 컴파일 및 재구동

```
# wscfl -I http.m
# wsdown
# wsboot
```

WEB-22 (하)	웹 서비스 〉 3. 보안 설정
	에러 페이지 관리
개요	
점검 내용	에러 페이지 내 불필요 정보 노출 여부 및 필수 에러 코드에 대해 일원화된 에러 페이지 관리 여부 점검
점검 목적	에러 페이지에서 웹 서버 버전 및 종류, OS 정보 등 웹 서버와 관련된 불필요한 정보 및 에러 코드를 통한 기술적 취약점이 노출되는 것을 최소화하기 위함
보안 위협	• 에러 페이지에서 불필요한 정보가 노출될 경우 공격자에 의해 해당 버전의 알려진 취약점 등을 이용하여 시스템 구조와 특성 노출 및 해당 취약점을 통한 공격의 위험이 존재함 • 필수 에러 코드에 대해 일원화된 에러 페이지로 관리하지 않는 경우 에러 코드를 통해 각종 정보 유추의 위험이 존재함
참고	-
점검 대상 및 판단 기준	
대상	Apache, Tomcat, Nginx, IIS, JEUS, WebtoB
판단 기준	**양호 :** 웹 서비스 에러 페이지가 별도로 지정된 경우
	취약 : 웹 서비스 에러 페이지가 별도로 지정되지 않거나 에러 발생 시 중요 정보가 노출되는 경우
조치 방법	필수 에러 코드에 대해 일원화된 에러 페이지 사용 및 에러 페이지 내 불필요 정보 노출 제한 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● Apache

Step 1) httpd.conf 파일 내 에러 코드별 에러 페이지 설정 정보 확인 후 별도의 일원화된 에러 페이지 설정

```
# vi /[Apache 설치 디렉터리]/sites-available/000-default.conf
ErrorDocument 400 /error.html
ErrorDocument 401 /error.html
(이하 생략)
```

Step 2) Apache 재구동

```
# systemctl restart apache2
```

Tomcat

Step 1) web.xml 파일 내 에러 코드별 에러 페이지 설정 정보 확인 후 별도의 일원화된 에러 페이지 설정

```
# vi /[Tomcat 설치 디렉터리]/conf/web.xml
<error-page>
  <error-code>404</error-code>
  <location>/error/404.html</location>
  (이하 생략)
</error-page>
```

Step 2) Tomcat 재구동

```
# systemctl restart tomcat
```

Nginx

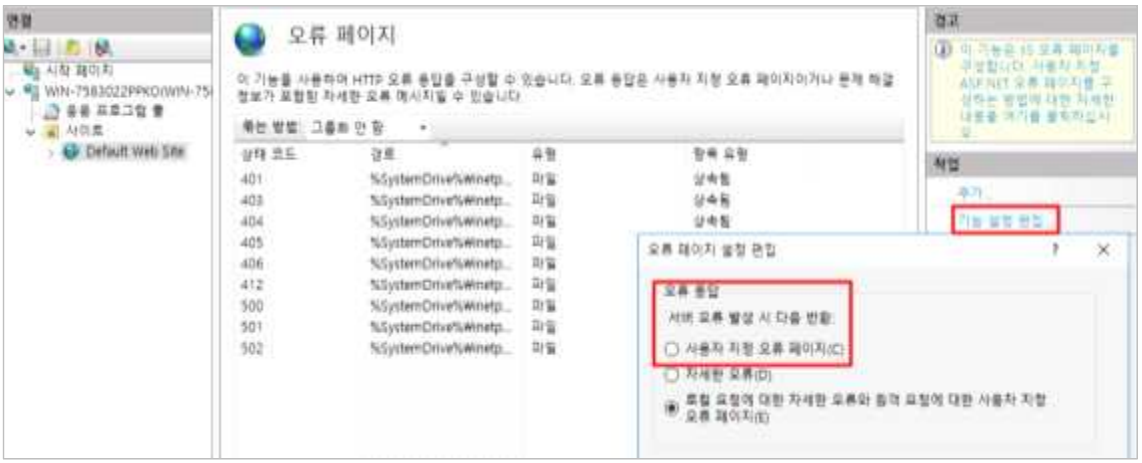
Step 1) nginx.conf 파일 내 에러 코드별 에러 페이지 설정 정보 확인 후 별도의 일원화된 에러 페이지 설정

```
# vi /[Nginx 설치 디렉터리]/conf/nginx.conf
server {
   ...
        error_page 404 /404.html;
        error_page 500 502 503 504 /50x.html;
        location = /404.html {
                root html;
                internal;
        }
        location = /50x.html {
                root html;
                internal;
        }
        (이하 생략)
}
```

IIS

Step 1) 오류 페이지 확인 후 설정

제어판 > 관리 도구 > IIS(인터넷 정보 서비스) 관리자 > 해당 웹사이트 > [오류 페이지] > [작업] 탭 내 [기능 설정 편집] > '서버 오류 발생 시 다음 반환' 항목을 '사용자 지정 오류 페이지'로 설정



[오류 페이지 설정 편집]

JEUS

Step 1) web.xml(또는 webcommon.xml) 파일 내 에러 메시지 설정 확인

vi /[JEUS 설치 디렉터리]/conf/web.xml(또는 webcommon.xml)

<error-page>

<error-code>404</error-code>

<location>404.html</location>

(이하 생략)

</error-page>

Step 2) 설정한 에러 메시지 내용 확인

vi /[WebtoB 설치 디렉터리]/docs/404.html

HTTP Error 404 - Service unavailable

Step 3) Server 설정 파일 VHOST, NODE, ERRORDOCUMENT에 오류 메시지 설정 확인

vi /[JEUS 설치 디렉터리]/conf/web.xml(또는 webcommon.xml)

HTTP Error 404 - Service unavailable

Step 4) 일원화된 오류 메시지 설정

vi /[JEUS 설치 디렉터리]/docs/404.html

죄송합니다. 요청하신 페이지를 찾을 수 없습니다.

WebtoB

Step 1) Server 설정 파일 VHOST, NODE, ERRORDOCUMENT에 설정한 오류 메시지 설정 확인 후 별도의 일원화된 에러 페이지 설정

```
# vi /[WebtoB 설치 디렉터리]/config/http.m
*ERRORDOCUMENT
503                  status = 503,
                     url = "/503.html“
```

Step 2) 설정한 에러 메시지 내용 확인

```
# vi /[WebtoB 설치 디렉터리]/docs/503.html
HTTP Error 503 - Service unavailable
```

Step 3) 일원화된 오류 메시지 설정

```
# vi /[WebtoB 설치 디렉터리]/docs/503.html
죄송합니다. 요청하신 페이지를 찾을 수 없습니다.
```

Step 4) 설정 파일 컴파일 및 재구동

```
# wscfl -I http.m
# wsdown
# wsboot
```

※ 일원화된 페이지에서의 불필요한 정보 노출 제한 및 웹 서비스가 제공하는 서비스에 대한 오류 코드별 에러 페이지 설정 필요

※ 예시와 같이 에러 코드 및 웹 버전이 출력되지 않도록 설정

[에러 페이지 출력]

WEB-23 (중)	웹 서비스 〉 3. 보안 설정
	LDAP 알고리즘 적절하게 구성
개요	
점검 내용	LDAP 연결 시 취약한 알고리즘 사용 제한 설정 여부 점검
점검 목적	LDAP 연결 시 안전한 비밀번호 다이제스트 알고리즘을 사용하여 비밀번호 평문 전송 시 발생할 수 있는 스니핑 등의 공격에 대비하기 위함
보안 위협	취약한 다이제스트 알고리즘을 사용하는 경우 공격자의 스니핑, 무차별 공격 등을 통해 인증 정보가 노출될 위험이 존재함
참고	※ LDAP(Lightweight Directory Access Protocol): 네트워크상에서 조직이나 개인정보 혹은 파일이나 디바이스 정보 등을 조회·관리하는 표준 프로토콜
점검 대상 및 판단 기준	
대상	Tomcat
판단 기준	**양호 :** LDAP 연결 인증 시 안전한 비밀번호 다이제스트 알고리즘을 사용하는 경우
	취약 : LDAP 연결 인증 시 안전한 비밀번호 다이제스트 알고리즘을 사용하지 않는 경우
조치 방법	LDAP 연결 인증 시 SHA-256 이상의 알고리즘을 사용하도록 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● Tomcat

Step 1) 비밀번호 다이제스트 알고리즘 확인 (LDAP 종류별 암호화 알고리즘 지원 여부 확인)

```
# grep 'digest=' /[Tomcat 설치 디렉터리]/conf/server.xml
digest="SSHA"
```

Step 2) 비밀번호 다이제스트 알고리즘 설정

```
# vi /[Tomcat 설치 디렉터리]/conf/server.xml
digest="SHA-256"
```

Step 3) Tomcat 재구동

```
# systemctl restart tomcat
```

※ SHA-256 이상 암호화 알고리즘 권고

WEB-24 (중)	웹 서비스 〉 3. 보안 설정
	별도의 업로드 경로 사용 및 권한 설정
개요	
점검 내용	웹 서비스 제공 시 이용되는 파일 전송의 업로드 경로를 별도의 디렉터리 사용 및 적절한 권한 설정 여부 점검
점검 목적	웹 서버 루트 디렉터리 내 업로드 경로가 아닌 별도의 디렉터리에서 파일을 업로드할 수 있도록 하여 루트 디렉터리 내 악의적인 파일 업로드 및 실행을 방지하기 위함
보안 위협	웹 서버 내 별도의 파일 업로드 경로 사용 및 적절한 권한 설정을 하지 않을 경우, 악의적인 목적을 가진 파일을 업로드하여 시스템 침투, 중요 정보 유출 및 변조 등의 침해사고의 가능성이 있음
참고	-
점검 대상 및 판단 기준	
대상	Apache, Tomcat, Nginx, IIS, JEUS, WebtoB
판단 기준	**양호 :** 별도의 업로드 경로를 사용하고 일반 사용자의 접근 권한이 부여되지 않은 경우
	취약 : 별도의 업로드 경로를 사용하지 않거나, 일반 사용자의 접근 권한이 부여된 경우
조치 방법	기본 경로가 아닌 별도의 업로드 경로를 지정하고, 해당 경로에 대한 일반 사용자의 접근 권한을 제한하도록 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● Apache

Step 1) apache2.conf 파일 내 업로드 경로 및 웹서비스 디렉터리 경로 확인

```
# vi /[Apache 설치 디렉터리]/apache2/apache2.conf(또는 apache2.conf)
<Directory /var/www/html/uploads>
  Options None
  AllowOverride None
  Require all denied
</Directory>
```

Step 2) 별도 업로드 경로 생성

```
# mkdir [웹서비스 디렉터리 외 경로]
# mkdir /var/www/html/uploads
```

Step 3) 파일 실행 권한 확인

```
# ls -al /[Apache 업로드 디렉터리]
```

Step 4) 업로드 디렉터리 권한 설정

```
# chmod 750 /var/www/html/uploads/
# chown www-data:www-data /var/www/html/uploads/
```

Step 5) apache2.conf 파일 내 업로드 디렉터리 접근제한 설정

```
# vi /[Apache 설치 디렉터리]/apache2/apache2.conf
<Directory "/var/www/html/uploads/">
  Require all denied
</Directory>
```

● Tomcat

Step 1) server.xml 파일 내 Context 요소 allowLinking 옵션 설정 (기본값 : 업로드 디렉터리 경로 존재하지 않음)

```
# vi /[Tomcat 설치 디렉터리]/conf/context.xml
<servlet>
  <servlet-name>fileUploadServlet</servlet-name>
  <servlet-class>com.example.FileUploadServlet</servlet-class>
</servlet>
```

Step 2) 별도의 업로드 경로 생성

```
# mkdir [웹서비스 디렉터리 외 경로]
# mkdir /var/www/html/uploads
```

Step 3) 업로드 디렉터리 권한 설정

```
chmod 750 /var/www/html/uploads/
chown tomcat:tomcat /var/www/html/uploads/
```

Step 4) 지정한 디렉터리 권한을 웹 서비스에서 사용

● Nginx

Step 1) nginx.conf 파일 내 업로드 경로 확인 및 웹서비스 디렉터리 경로 사용 여부 확인

```
#vi /[Nginx 설치 디렉터리]/conf/nginx.conf
```

Step 2) 별도의 업로드 경로 생성

```
mkdir [웹서비스 디렉터리 외 경로]
mkdir /var/www/html/uploads
```

Step 3) 업로드 디렉터리의 권한 설정

chmod 750 /var/www/html/uploads/

chown www-data:www-data /var/www/html/uploads/

Step 4) nginx.conf 파일 내 업로드 디렉터리 접근제한 설정

#vi /[Nginx 설치 디렉터리]/conf/nginx.conf

```
location /uploads/ {
  alias /var/www/html/uploads/;
  autoindex on;
}
```

Step 5) 변경된 설정 내용을 적용하기 위하여 Nginx 데몬 재구동

#systemctl restart nginx

● IIS

Step 1) 업로드 디렉터리 경로 확인

제어판 > 관리 도구 > 인터넷 정보 서비스(IIS) 관리자 > 해당 웹사이트 > 기본 설정 > '실제 경로'에서 홈 디렉터리 위치 확인

Step 1) 실제 경로에 입력된 홈 디렉터리로 업로드 디렉터리 확인

[홈 디렉터리 위치 확인]

Step 2) 웹 서비스 외부에 업로드 디렉터리를 생성

[외부 업로드 경로] > 새 폴더 생성 및 이름 지정

Step 3) 새로 생성한 폴더에 대한 권한 설정

[외부 업로드 파일] > 속성 > 보안 > 편집 > [IIS 구동 계정 그룹] 추가 및 쓰기 권한 부여 설정

JEUS

Step 1) web.xml 파일 내 파일 업로드 경로 확인

```
# vi /[JEUS 설치 디렉터리]/conf/web.xml(또는 webcommon.xml)
<context-param>
  <param-name>uploadDir</param-name>
  <param-value>/path/to/your/upload/directory</param-value>
</context-param>
```

Step 2) 파일 업로드 경로 권한 확인

```
# ls –al /[JEUS 업로드 디렉터리]
```

Step 3) 업로드 디렉터리 권한 설정

```
# chmod 750 # ls –al  /[JEUS 업로드 디렉터리]
# chown jeus:jeus /[JEUS 업로드 디렉터리]
```

WebtoB

Step 1) http.m 파일 내 파일 업로드 경로 확인

```
# cat /root/webtob/config/http.m
*ALIAS
alias_upload    URI = "/upload/", RealPath = "/home/tmax/webtob/uploads/"
```

Step 2) 파일 업로드 경로 권한 확인

```
# ls –al /[WebtoB 업로드 디렉터리]
```

Step 3) 업로드 디렉터리의 권한 설정

```
# chmod 750 # ls –al /[WebtoB 업로드 디렉터리]
# chown tmax:tmax /[WebtoB 업로드 디렉터리]
```

WEB-25 (상)	웹 서비스 〉 4. 패치 및 로그 관리
	주기적 보안 패치 및 벤더 권고사항 적용
개요	
점검 내용	최신 보안 패치 적용 여부 점검
점검 목적	주기적인 최신 보안 패치를 통해 보안성 및 시스템 안정성을 확보하기 위함
보안 위협	주기적으로 최신 보안 패치를 적용하지 않을 경우, 알려진 취약점을 이용한 공격 또는 새로운 공격에 대한 침해사고 발생 위험이 존재함
참고	※ 최신 버전을 사용하도록 권고하고 있으나 시스템 운영상 적용이 어려운 경우 최신이 아닌 취약점이 존재하지 않는 버전도 허용하고 있음
점검 대상 및 판단 기준	
대상	Apache, Tomcat, Nginx, IIS, JEUS, WebtoB
판단 기준	**양호 :** 최신 보안 패치가 적용되어 있으며, 패치 적용 정책을 수립하여 주기적인 패치 관리를 하는 경우
	취약 : 최신 보안 패치가 적용되어 있지 않거나 패치 적용 정책을 수립 및 주기적인 패치 관리를 하지 않는 경우
조치 방법	패치 적용에 따른 서비스 영향 정도를 정확히 파악하여 주기적인 패치 적용 정책 수립 및 적용하도록 설정
조치 시 영향	시스템 영향도를 파악하여 충분한 테스트 후 적용 권고

점검 및 조치 사례

● Apache

Step 1) 웹 서버 버전과 최신 패치 버전을 비교하여 확인

/[Apache 설치 디렉터리]/httpd –v

```
[root@localhost sbin]# httpd -v
Server version: Apache/2.4.37 (Rocky Linux)
Server built:   Jul  1 2024 14:01:13
[root@localhost sbin]#
```

[Apache 웹 서버 버전 확인]

Step 2) Apache 사이트를 통해 주기적으로 버전 점검을 하며, 최신 버전 적용 시 충분한 테스트 후 적용 권고

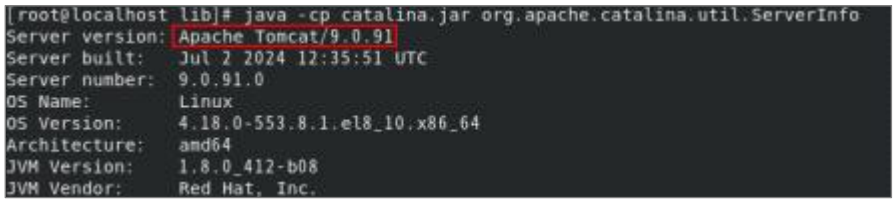
※ 참고 사이트: http://httpd.apache.org/download.cgi

Tomcat

Step 1) 웹 서버 버전과 최신 패치 버전을 비교하여 확인

cd /[Tomcat 설치 디렉터리]/lib

java -cp catalina.jar org.apache.catalina.util.ServerInfo



[Tomcat 웹 서버 버전 확인]

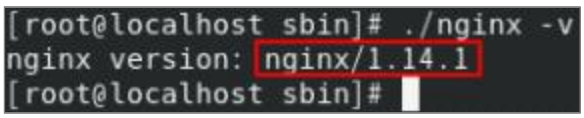
Step 2) Tomcat 사이트를 통해 주기적으로 버전 점검을 하며, 최신 버전 적용 시 충분한 테스트 후 적용 권고

※ 참고 사이트: https://tomcat.apache.org/

Nginx

Step 1) 웹 서버 버전과 최신 패치 버전을 비교하여 확인

/[Nginx Dir]/nginx –v



[Nginx 웹 서버 버전 확인]

Step 2) Nginx 사이트를 통해 주기적으로 버전 점검을 하며, 최신 버전 적용 시 충분한 테스트 후 적용 권고

※ 참고 사이트: https://nginx.org/en/download.html

IIS

Step 1) 웹 서버 버전과 최신 패치 버전을 비교하여 확인

reg query “HKLM\SOFTWARE\Microsoft\InetStp” /v VersionString

[Windows Server 버전 확인]

Step 2) IIS 사이트를 통해 주기적으로 버전 점검을 하며, 최신 버전 적용 시 충분한 테스트 후 적용 권고

※ 참고 사이트: https://www.iis.net/downloads/microsoft

- JEUS

Step 1) 웹 서버 버전과 최신 패치 버전을 비교하여 확인

jeusadmin -version 또는 jeusadmin –fullversion

Step 2) JEUS 사이트를 통해 주기적으로 버전 점검을 하며, 최신 버전 적용 시 충분한 테스트 후 적용 권고

※ 참고 사이트: https://technet.tmaxsoft.com/ko/front/download/findDownloadList.do

- WebtoB

Step 1) 웹 서버 버전과 최신 패치 버전을 비교하여 확인

wscfl –version

Step 2) WebtoB 사이트를 통해 주기적으로 버전 점검을 하며, 최신 버전 적용 시 충분한 테스트 후 적용 권고

※ 참고 사이트: https://technet.tmaxsoft.com/ko/front/download/findDownloadList.do? cmProductCode=0102

WEB-26 (중)	웹 서비스 〉 4. 패치 및 로그 관리
	로그 디렉터리 및 파일 권한 설정
개요	
점검 내용	비인가자의 로그 디렉터리 및 파일의 접근을 차단하기 위한 권한 적절성 여부 점검
점검 목적	로그 파일에 공격자에게 유용한 정보가 들어있을 수 있으므로 권한 관리를 통해 비인가자에 의한 정보유출, 로그 파일의 훼손 및 변조를 방지하기 위함
보안 위협	로그 디렉터리 및 파일에 적절한 권한이 설정되어 있지 않은 경우, 비인가자가 로그 파일에 접근할 수 있으므로 사용자 및 시스템 정보유출, 로그 파일 조작 등의 공격 위험이 존재함
참고	-
점검 대상 및 판단 기준	
대상	Apache, Tomcat, Nginx, IIS, JEUS, WebtoB
판단 기준	**양호 :** 로그 디렉터리 및 파일에 일반 사용자의 접근 권한이 없는 경우
	취약 : 로그 디렉터리 및 파일에 일반 사용자의 접근 권한이 있는 경우
조치 방법	로그 디렉터리 및 파일에 일반 사용자 접근 권한 제거 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

- **Apache**

Step 1) 로그 디렉터리 및 파일 권한 확인

```
# ls –al <Aapche 로그 디렉터리>
```

Step 2) 로그 디렉터리 및 파일의 불필요 권한 삭제

```
# chmod o-rwx /<Apache 로그 파일>
```

- **Tomcat**

Step 1) 로그 디렉터리 및 파일 권한 확인

```
# ls –al /<Tomcat 로그 디렉터리>
```

Step 2) 로그 디렉터리 및 파일의 불필요 권한 삭제

```
# chmod o-rwx /<Tomcat 로그 파일>
```

Nginx

Step 1) 로그 디렉터리 및 파일의 권한 확인

ls –al /<Nginx 로그 디렉터리>

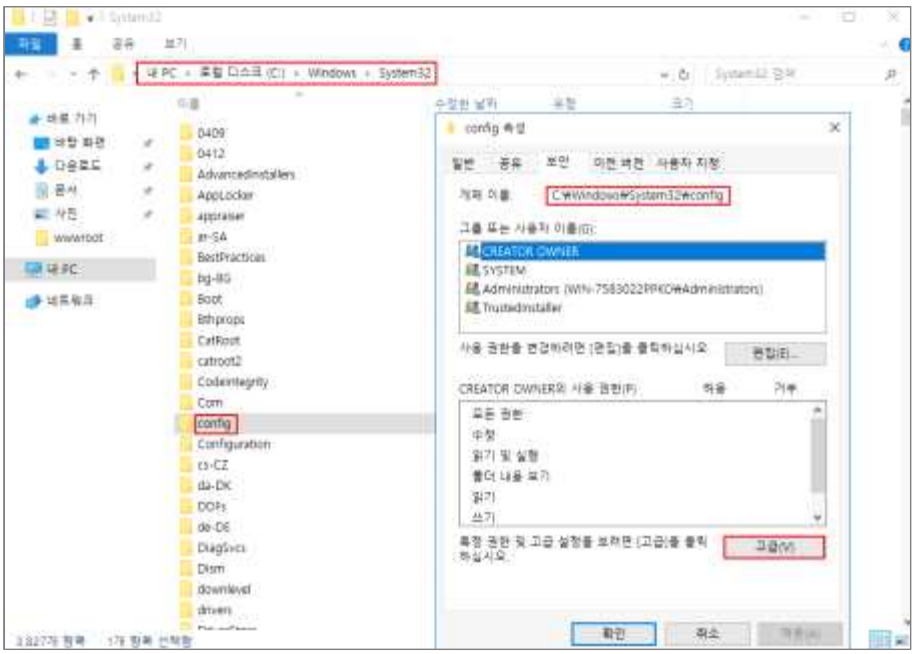
Step 2) 로그 디렉터리 및 파일의 불필요 권한 삭제

chmod o-rwx /<Nginx 로그 디렉터리>

IIS

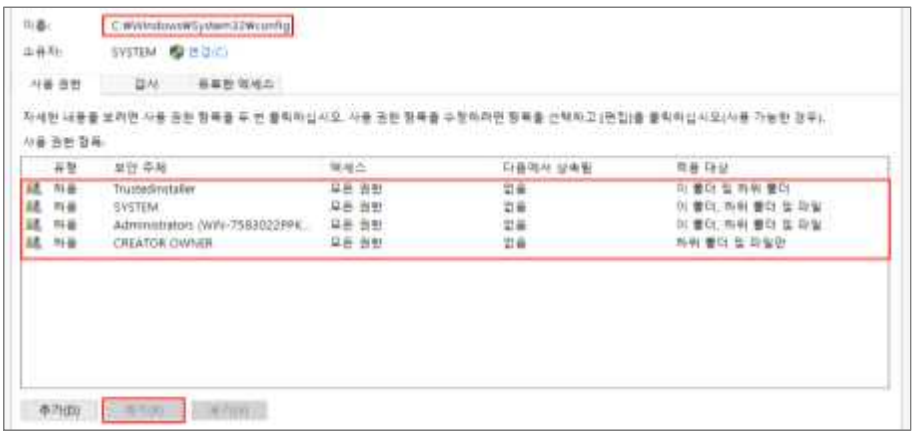
Step 1) 로그 디렉터리 및 파일의 권한 확인

파일 탐색기(C:\Windows\System32\config) > 로그 디렉터리 > 속성 > 보안 > 고급



[config 속성 확인]

Step 1) Everyone 권한 제거



[config 타 사용자 권한 확인]

※ 일반적으로 시스템 로그는 C:\Windows\system32\config 파일에 저장되지만, 서비스 로그 파일은 각각의 서비스마다 로그 저장 위치가 다름. 웹 서버에 많이 사용하는 IIS 경우, C:\Windows\system32\LogFiles에 저장됨.

JEUS

Step 1) 도메인별 logs 파일 권한 확인

ls –al /[JEUS 설치 디렉터리]/domains/jeus_domain/servers/sample/logs

Step 2) 로그 디렉터리 권한을 750으로 변경

chmod 750 /[JEUS 설치 디렉터리]/domains/jeus_domain/servers/sample/logs

Step 3) 로그 파일의 권한을 640으로 변경 (기본값: 644)

chmod 640 /[JEUS 설치 디렉터리]/domains/jeus_domain/servers/sample/logs/[로그 파일]

※ 그 외 로그 파일의 권한도 동일하게 설정

WebtoB

Step 1) logs 파일 권한 확인

ls –al /home/tmax/webtob/log/

-rw------- 1 tmax tmax 674 8월 19 16:06 access.log_08192024

Step 2) 로그 디렉터리 권한을 750으로 변경

chmod 750 /[WebtoB 설치 디렉터리]/log/

Step 3) 로그 파일의 권한을 640으로 변경 (기본값: 644)

chmod 640 /[WebtoB 설치 디렉터리]/log/[로그 파일]

※ 그 외 로그 파일의 권한도 동일하게 설정